МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ
ВЫСШЕГО ОБРАЗОВАНИЯ
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности

ОТЧЁТ

по научно-исследовательской работе студента

Тема: «Разработка интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes в условиях компрометации контейнерных приложений»

РАСЧЁТНО-ПОЯСНИТЕЛЬНАЯ ЗАПИСКА

Разработал студент
гр. ИБ-201 «____»_____ К. Ю. Полыга
подпись, дата инициалы, фамилия

Руководитель работы:
д-р техн. наук, проф. «____»_____ О. Н. Чопоров
должность подпись, дата инициалы, фамилия

Защищена _____ Оценка _____
дата

Воронеж 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 4

1 Инфраструктура контейнеризации Kubernetes как объект защиты и анализ средств оценки её киберрисков 13

1.1 Инфраструктура контейнеризации в корпоративной автоматизированной информационной системе 14

1.1.1 Понятие контейнеризации и оркестрации контейнерных приложений 14

1.1.2 Компоненты кластера Kubernetes и границы доверия между ними 15

1.1.3 Статистика и тенденции инцидентов безопасности в контейнерных средах 17

1.2 Декомпозиция кластера на активы и границы доверия 19

1.3 Нормативное обеспечение защиты инфраструктуры контейнеризации 20

1.4 Недостатки конфигурации кластера как источник киберрисков 23

1.5 Информационное обеспечение риск-анализа контейнерных сред 25

1.5.1 Базы данных уязвимостей и угроз: CVE, NVD, банк данных угроз ФСТЭК России 25

1.5.2 Профили безопасности NIST SP 800-190 и CIS Kubernetes Benchmark 26

1.5.3 Матрица MITRE ATT&CK for Containers 27

1.6 Анализ существующих средств анализа защищённости контейнерных сред 28

1.7 Дерево угроз и индуцированных ими рисков инфраструктуры контейнеризации 30

1.8 Риск-ландшафт инфраструктуры контейнеризации 33

1.9 Выявление противоречий и постановка задач исследования 37

1.10 Формирование требований к методическому, алгоритмическому и программному обеспечению 39

1.11 Выводы по первому разделу 41

2 Комплекс мер риск-регулирования инфраструктуры контейнеризации .. 44
2.1 Классификация мер риск-регулирования по масштабности и профильности 44
2.2 Частные регламенты противодействия компрометации контейнерных приложений 46
2.2.1 Частный регламент выявления и регистрации инцидентов .. 46
2.2.2 Частный регламент реагирования на инциденты 47
2.2.3 Частный регламент ликвидации последствий инцидентов ... 48
2.3 Оценка достигаемого снижения меры риска 49
2.4 Выводы по второму разделу 50
ЗАКЛЮЧЕНИЕ 52
СПИСОК ЛИТЕРАТУРЫ 55
ПРИЛОЖЕНИЕ А. Фрагмент базы знаний соответствий «недостаток конфигурации кластера – эксплуатирующая техника – наступающий ущерб» 66
ПРИЛОЖЕНИЕ Б. Матрица целеполагания исследования 68

ВВЕДЕНИЕ

Переход корпоративных информационных систем к микросервисной архитектуре привёл к тому, что основной средой исполнения прикладного программного обеспечения стала инфраструктура контейнеризации, а система оркестрации Kubernetes – фактическим стандартом управления такой средой. Кластер объединяет в едином контуре плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов контейнеров, каждый из которых обладает собственной границей доверия и собственным набором полномочий. Тем самым кластер определяет, какое приложение, к каким ресурсам инфраструктуры и в каком объёме прав допущено, а следовательно, задаёт границы того ущерба, который может быть нанесён организации при переходе контейнерного приложения под контроль нарушителя. Особенность рассматриваемого объекта состоит в том, что компрометация единственной рабочей нагрузки ею не ограничивается: избыточные полномочия сервисного аккаунта, примонтированный каталог узла или доступный сокет среды исполнения контейнеров превращают прикладной инцидент в компрометацию узла, а затем и плоскости управления, обесценивая прочие применённые средства защиты информации.

Распространённость рассматриваемого объекта защиты и характер наступающих в нём инцидентов подтверждаются данными зарубежных отраслевых исследований. По результатам ежегодного опроса State of Kubernetes Security Report доля организаций, отметивших не менее одного инцидента безопасности контейнерной среды в течение предшествовавших двенадцати месяцев, составила 93 % в 2022 году, 90 % в 2023 году, 89 % в 2024 году и 86 % в 2025 году, причём преобладающей причиной инцидента на всём протяжении наблюдения остаётся не уязвимость образа, а недостаток конфигурации: его доля изменялась в пределах от 45 до 53 % при доле инцидентов, вызванных уязвимостью программного обеспечения, от 27 до 33 % [65]. По данным исследования Cloud-Native Security and Usage Report доля учётных записей и сервисных аккаунтов кластеров, которым предоставлены полномочия, фактически не используемые рабочей нагрузкой,

возросла с 84 % в 2022 году до 98 % в 2025 году, а доля рабочих нагрузок, исполняемых с правами суперпользователя, составила порядка трети от общего их числа [66]. Согласно ежегодному исследованию Cloud Native Computing Foundation, оркестрация контейнерных приложений применяется в промышленной эксплуатации в 66 % организаций при общем уровне применения технологии 84–96 %, что определяет масштаб распространения объекта защиты [67]. Отчёт Data Breach Investigations Report фиксирует устойчивый рост доли инцидентов, в которых начальным вектором выступила эксплуатация уязвимости или недостатка конфигурации внешнего сервиса, с 14 % в 2023 году до 20 % в 2025 году [68].

Аналогичная тенденция наблюдается и в отечественной практике. По данным экспертно-аналитического центра InfoWatch число зарегистрированных утечек информации из российских организаций составило порядка 660 в 2023 году и превысило 1000 в 2024 году, при этом доля инцидентов, в которых нарушителем использовались штатные средства администрирования и предоставленные полномочия, а не вредоносное программное обеспечение, устойчиво возрастает [69]. Аналитические отчёты об актуальных киберугрозах показывают, что доля успешных атак на организации, приведших к нарушению основной деятельности, в 2024–2025 годах превысила треть от общего их числа, а среди применяемых нарушителем техник преобладают получение и использование действительных учётных данных и эксплуатация недостатков конфигурации внешних сервисов [70]. В банке данных угроз безопасности информации ФСТЭК России по состоянию на начало 2026 года зарегистрировано 222 угрозы безопасности информации, из которых к средам виртуализации и контейнеризации применимы 24 угрозы, включая угрозы выхода за пределы виртуальной машины, нарушения изоляции пользовательских данных и несанкционированного доступа к гипервизору и средствам управления средой виртуализации [38]. Отдельно следует отметить, что перечисленные угрозы описаны применительно к технологии виртуализации в целом и не содержат детализации по компонентам системы оркестрации контейнерных приложений.

Приведённые данные свидетельствуют о смене характера атаки на контейнерную инфраструктуру: нарушитель всё чаще не эксплуатирует программный дефект в образе, а использует штатно предоставленные рабочей нагрузке полномочия и допущенные при развёртывании ослабления изоляции. Между тем действующий аппарат риск-анализа исторически построен вокруг уязвимостей программного обеспечения. Банк данных угроз безопасности информации ФСТЭК России, международные реестры CVE и NVD, а также средства количественной оценки – вектор CVSS версий 3.1 и 4.0 и прогноз вероятности эксплуатации EPSS – описывают дефект программного или аппаратного обеспечения и не предназначены для описания состояния конфигурации кластера [38-40, 54-56]. Привилегированный режим пода, монтирование узловых каталогов, избыточные привязки ролей механизма RBAC, неограниченный доступ к API-серверу и отсутствие политик допуска рабочих нагрузок не являются уязвимостями в принятом понимании, не получают идентификатора, не регистрируются ни в одном из перечисленных источников и по этой причине не попадают в расчёт меры риска, хотя именно они определяют вероятность успешной компрометации и величину её последствий.

Существующие средства анализа защищённости контейнерных сред – Kubescape, kube-bench, Trivy и Falco [58-61] – выполняют проверку объектов кластера на соответствие профилю безопасности, обнаруживают уязвимости образов и фиксируют аномальное поведение среды исполнения, однако устанавливают лишь факт наличия или отсутствия несоответствия, не переводя его в меру риска. Проверка носит пообъектный характер: каждый объект кластера оценивается изолированно, вследствие чего сочетаемость недостатков, образующих цепочку «выход за границы контейнера – компрометация узла – доступ к плоскости управления», остаётся вне рассмотрения. Между тем именно связность недостатков конфигурации определяет достижимость целевых активов кластера, а значит, и действительную величину риска, которая должна оцениваться в целом и переоцениваться непрерывно, по событиям изменения состава рабочих нагрузок, версий образов и политик доступа.

Степень проработанности темы. Вопросы риск-анализа в области защиты информации получили развитие в трудах отечественной научной школы, в которых разработаны методики оценки рисков успешности реализации кибератак, построения риск-ландшафтов сетевых атак и организационно-правового обеспечения противодействия им [71-80]. Требования к защите информации в информационных системах установлены нормативными документами ФСТЭК России [4-7] и национальными стандартами [8-16]. Особенности обеспечения безопасности приложений, исполняемых в контейнерной среде, изложены в руководстве NIST SP 800-190 и наборе проверок CIS Kubernetes Benchmark [19, 25], а техники, применяемые нарушителем в инфраструктуре контейнеризации, систематизированы в матрице MITRE ATT&CK for Containers [43, 44]. Вместе с тем в известных работах объектом риск-анализа выступают программное обеспечение и информационная система в целом, а контейнерное приложение рассматривается как носитель уязвимостей, а не как начальное звено цепочки компрометации инфраструктуры. Не решённой остаётся задача количественного сопоставления рабочих нагрузок кластера по вероятности компрометации и величине наступающего ущерба, что и определяет горизонты настоящего исследования.

Актуальность темы исследования обусловлена наличием противоречий между:

– объективной необходимостью рассматривать кластер как связную систему активов с различными границами доверия – плоскостью управления, узлами, рабочими нагрузками и реестром образов – и сложившейся практикой оценки защищённости контейнерных сред по отдельным образам и их уязвимостям, при которой компрометация контейнерного приложения считается конечным событием, а не начальным звеном цепочки;

– потребностью в едином описании недостатков конфигурации кластера – привилегированных подов, монтирования узловых каталогов, избыточных привязок RBAC, неограниченного доступа к API-серверу – и ориентированностью баз данных уязвимостей – CVE, NVD, банка данных угроз ФСТЭК России – на дефекты

программного кода, вследствие чего перечисленные недостатки не получают идентификатора и выпадают из риск-анализа;

– необходимостью количественного выражения критичности недостатков конфигурации кластера и инструментальной базой оценки критичности, представленной метриками CVSS версий 3.1 и 4.0 и прогнозной оценкой эксплуатации EPSS, которые построены для уязвимостей с присвоенным идентификатором и накопленной статистикой эксплуатации, отсутствующей у конфигурационных недостатков;

– необходимостью учёта сочетаемости недостатков, образующих цепочки «выход за границы контейнера – компрометация узла – доступ к плоскости управления», и пообъектным характером проверок средств анализа защищённости Kubescape, kube-bench, Trivy и Falco, оценивающих каждый объект кластера изолированно;

– потребностью в удержании оценки риска в актуальном состоянии при непрерывном изменении состава рабочих нагрузок, версий образов и политик доступа и статичностью действующих методик, предполагающих разовое обследование кластера по фиксированному профилю соответствия.

Объектом исследования является инфраструктура контейнеризации Kubernetes автоматизированной информационной системы организации, включающая плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов контейнеров.

Предметом исследования являются модели, методики и алгоритмы оценки и регулирования киберрисков, позволяющие количественно описывать вероятность компрометации контейнерных приложений и величину наступающего при этом ущерба, а также поддерживать полученные оценки в актуальном состоянии при изменении конфигурации кластера.

Целью исследования является повышение защищённости автоматизированных информационных систем за счёт разработки интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes в условиях компрометации контейнерных приложений.

Для достижения поставленной цели необходимо решить следующие задачи:

– выполнить декомпозицию инфраструктуры контейнеризации на активы и границы доверия и построить на её основе дерево угроз и индуцированных ими рисков, наступающих при компрометации контейнерных приложений;

– сформировать базу знаний соответствий недостатков конфигурации кластера и эксплуатирующих их техник на основе CIS Kubernetes Benchmark, NIST SP 800-190 и матрицы MITRE ATT&CK for Containers [19, 25, 44] с привязкой каждой пары к наступающему ущербу;

– разработать методику количественной оценки вероятности успешной компрометации контейнерного приложения и наступающего ущерба на основе адаптации базовых, контекстных и средовых метрик CVSS 4.0 [55] к контексту кластера;

– сформировать типовые сценарии компрометации кластера в виде путей достижимости активов, размеченных техниками MITRE ATT&CK for Containers, с расчётом риска успешности каждого сценария и построить риск-ландшафт кластера;

– создать интеллектуальную систему оценки и регулирования киберрисков кластера, выполняющую классификацию рабочих нагрузок по уровню риска средствами машинного обучения и пересчёт риск-ландшафта при смене снимка конфигурации, и сформировать комплекс мер регулирования, классифицированных по масштабности и профильности.

Методы исследования. При решении поставленных задач применялись методы системного анализа и декомпозиции сложных систем, аппарат теории рисков, методы теории вероятностей и математической статистики, теория графов при построении дерева угроз и графа достижимости активов кластера, методы машинного обучения с учителем при классификации рабочих нагрузок по уровню риска, а также методы объектно-ориентированного программирования при разработке программного обеспечения интеллектуальной системы.

Решение поставленных задач позволило сформировать следующие результаты, выносимые на защиту:

– модель объекта защиты в виде декомпозиции кластера на активы и границы доверия и построенное на ней дерево угроз и индуцированных рисков;

– база знаний троек «недостаток конфигурации кластера – эксплуатирующая техника – наступающий ущерб», покрывающая все выделенные активы объекта защиты;

– методика и реализующий её алгоритм расчёта меры риска компрометации контейнерного приложения, определяемой как произведение вероятности наступления ущерба на его величину;

– множество сценариев компрометации, представленных путями в графе достижимости, и риск-ландшафт кластера, построенный по осям «актив кластера», «техника эксплуатации» и «мера риска»;

– программное обеспечение интеллектуальной системы с моделью классификации рабочих нагрузок по уровню риска и комплекс мер регулирования риск-ландшафта кластера с оценкой достигаемого снижения меры риска.

Новизна полученных результатов заключается в следующем:

– впервые дерево угроз построено для кластера как связной системы, в которой компрометация контейнерного приложения выступает начальным, а не конечным событием, что позволяет включить в рассмотрение переходы между границами доверия;

– впервые недостатки конфигурации Kubernetes, не обладающие идентификаторами уязвимостей, поставлены в однозначное соответствие техникам их эксплуатации и представлены в форме, пригодной для машинной обработки;

– впервые количественная оценка критичности получена для недостатков без идентификатора уязвимости за счёт переноса метрик на контекст кластера: уровень привилегий пода, пересекаемую границу доверия и доступность плоскости управления;

– впервые риск кластера определяется не суммой независимых несоответствий профилю, а достижимостью целевых активов по графу сценариев, что учитывает взаимное усиление недостатков конфигурации;

– впервые уровень риска рабочей нагрузки определяется обученной моделью по совокупности параметров её манифеста, а меры регулирования оцениваются величиной снижения меры риска, а не фактом соответствия профилю безопасности.

Практическая ценность полученных результатов состоит в следующем:

– применение модели объекта защиты позволяет специалисту очертить границы объекта защиты и получить перечень контролируемых узлов кластера при проектировании защиты контейнерной платформы;

– применение базы знаний позволяет получить готовый перечень проверяемых параметров кластера с указанием техники эксплуатации и ожидаемого ущерба без обращения к разрозненным источникам;

– применение методики позволяет оперативно вычислять параметры риска компрометации отдельной рабочей нагрузки и ранжировать нагрузки кластера по критичности;

– применение риск-ландшафта позволяет выявить сочетания недостатков с наибольшей мерой риска и сосредоточить защитные ресурсы на сценариях, ведущих к плоскости управления;

– применение разработанной системы снимает необходимость ручного аудита при каждом изменении кластера и даёт обоснование выбора мер защиты по критерию достигаемого снижения риска.

Теоретическая значимость результатов исследования определяется следующим образом:

– полученная декомпозиция может быть распространена на иные платформы оркестрации – OpenShift, Nomad – и служит основой для анализа защищённости сервисных сеток;

– полученное соответствие может быть расширено на шаблоны инфраструктуры как кода и политики допуска рабочих нагрузок, а также использовано для корреляционного анализа накопленных данных;

– полученный подход может быть распространён на иные классы объектов защиты, не обладающих идентификаторами уязвимостей;

– полученный граф достижимости может быть сужен до актуального множества сценариев либо расширен на мультикластерные и гибридные среды;

– полученное обеспечение может быть распространено на оптимизацию риск-ландшафта контейнерных сред различного назначения.

Апробация результатов. Результаты исследования планируются к докладу на научно-практических конференциях и семинарах, проводимых кафедрой систем информационной безопасности, а также к обсуждению в рамках научно-исследовательской работы обучающихся.

Публикация результатов. Результаты исследования планируются к опубликованию в научном журнале «Информация и безопасность», а также в сборниках трудов научно-практических конференций по направлению обеспечения информационной безопасности.

Отчёт о научно-исследовательской работе состоит из введения, двух разделов, заключения, списка литературы и двух приложений. В первом разделе выполняется исследование инфраструктуры контейнеризации Kubernetes как объекта защиты: проводится декомпозиция кластера на активы и границы доверия, устанавливается соответствие нормативных требований параметрам конфигурации, анализируются информационное обеспечение риск-анализа и существующие средства анализа защищённости контейнерных сред, строятся дерево угроз и индуцированных ими рисков и риск-ландшафт объекта защиты, выявляются противоречия, ставятся задачи исследования и формируются требования к разрабатываемому обеспечению. Во втором разделе вырабатывается комплекс мер риск-регулирования, классифицированных по масштабности и профильности, разрабатываются частные регламенты выявления, реагирования и ликвидации последствий инцидентов и выполняется оценка достигаемого снижения меры риска.

1 Инфраструктура контейнеризации Kubernetes как объект защиты и анализ средств оценки её киберрисков

Настоящий раздел посвящён обоснованию целеполагания и постановке задач исследования. В соответствии с методическими рекомендациями по выполнению работ в области обеспечения информационной безопасности [71] изложение строится от объекта защиты и присущих ему угроз через оценку индуцированных этими угрозами рисков к последующему риск-управлению. Исследование опирается на терминологию, принятую в отечественной научной школе [8, 71], согласно которой безопасность есть состояние защищённости от внешних и внутренних угроз, при котором риск реализации этих угроз не превышает допустимых значений; угроза – совокупность факторов, воздействие которых способно привести к ущербу; ущерб – совокупность негативных последствий реализации угроз; риск – возможность наступления ущерба от реализации угроз, а мера риска определяется произведением величины ожидаемого ущерба на вероятность его наступления.

Задачами раздела являются построение модели инфраструктуры контейнеризации Kubernetes как объекта защиты, выполнение её декомпозиции на активы и границы доверия, установление соответствия между нормативными требованиями к защите информации и параметрами конфигурации кластера, классификация недостатков конфигурации, анализ информационного обеспечения риск-анализа контейнерных сред и существующих средств анализа защищённости, построение дерева угроз и индуцированных ими рисков и риск-ландшафта объекта защиты, выявление противоречий, постановка задач исследования и формирование требований к разрабатываемому методическому, алгоритмическому и программному обеспечению.

1.1 Инфраструктура контейнеризации в корпоративной автоматизированной информационной системе

1.1.1 Понятие контейнеризации и оркестрации контейнерных приложений

Контейнеризация представляет собой разновидность виртуализации на уровне операционной системы, при которой прикладное программное обеспечение вместе с необходимыми ему библиотеками и зависимостями упаковывается в образ и исполняется изолированно от прочих приложений, но в среде общего ядра операционной системы узла. Изоляция обеспечивается механизмами ядра – пространствами имён, разграничивающими видимость процессов, сетевых интерфейсов, точек монтирования и идентификаторов пользователей, и контрольными группами, ограничивающими потребление вычислительных ресурсов. Принципиальное отличие контейнеризации от виртуализации на основе гипервизора состоит в том, что контейнеры не располагают собственным ядром: граница изоляции между контейнером и узлом реализуется программно, средствами того же ядра, которое обслуживает все исполняемые на узле рабочие нагрузки. Вследствие этого ослабление параметров изоляции, допущенное при развёртывании, переводит инцидент прикладного уровня в инцидент уровня инфраструктуры, что и определяет специфику рассматриваемого объекта защиты.

Жизненный цикл контейнерного приложения включает сборку образа, его размещение в реестре образов, получение образа узлом и запуск контейнера средой исполнения. Каждый из перечисленных этапов образует самостоятельную точку приложения усилий нарушителя: образ может содержать внесённый в него посторонний код, реестр – выдать подменённый образ, среда исполнения – запустить контейнер с избыточными полномочиями. Тем самым защищённость исполняемого приложения определяется не только его собственным кодом, но и параметрами всей цепочки, по которой это приложение оказалось на узле.

По мере роста числа контейнерных приложений их ручное размещение становится неосуществимым, вследствие чего применяются системы оркестрации, принимающие на себя планирование размещения рабочих нагрузок по узлам, их

масштабирование, организацию сетевого взаимодействия, предоставление хранилищ и управление конфиденциальными параметрами. Kubernetes является де-факто стандартом оркестрации контейнерных приложений и применяется как в собственных центрах обработки данных организаций, так и в облачных средах. Существенно, что система оркестрации не только управляет рабочими нагрузками, но и сама выступает носителем полномочий: она располагает учётными данными для обращения к реестру образов, хранит конфиденциальные параметры приложений и обладает возможностью запуска произвольной рабочей нагрузки на любом подчинённом узле. Компрометация системы оркестрации, таким образом, эквивалентна компрометации всех обслуживаемых ею приложений и данных.

1.1.2 Компоненты кластера Kubernetes и границы доверия между ними

Кластер Kubernetes образован двумя группами компонентов. Плоскость управления включает сервер программных интерфейсов kube-apiserver, являющийся единственной точкой обращения к кластеру и выполняющий аутентификацию, авторизацию и допуск запросов; распределённое хранилище etcd, содержащее полное состояние кластера, включая конфиденциальные параметры приложений; планировщик kube-scheduler, определяющий узел размещения рабочей нагрузки; и менеджер контроллеров kube-controller-manager, приводящий фактическое состояние кластера к заданному. Вычислительные узлы включают агент kubelet, управляющий жизненным циклом контейнеров на узле и обращающийся к серверу программных интерфейсов; сетевой агент kube-proxy; и среду исполнения контейнеров, непосредственно взаимодействующую с ядром операционной системы узла.

Рабочие нагрузки представлены подами – минимальными планируемыми единицами, объединяющими один или несколько контейнеров с общими пространствами имён. Каждому поду сопоставляется сервисный аккаунт, от имени которого выполняются обращения к серверу программных интерфейсов; объём предоставленных сервисному аккаунту прав определяется механизмом управления доступом на основе ролей. Реестр образов, располагающийся вне кластера либо в

его составе, хранит образы, из которых создаются контейнеры, и является точкой, определяющей доверие к исполняемому коду.

Перечисленные компоненты не равнозначны с точки зрения защиты информации: они располагают различным объёмом полномочий, обслуживают различные множества субъектов и влекут различный ущерб при компрометации. Соответствующее сопоставление приведено в таблице 1.

Таблица 1 – Компоненты кластера Kubernetes и последствия их компрометации

Компонент кластера	**Назначение и располагаемые полномочия**	**Последствия компрометации**
Сервер программных интерфейсов	Единственная точка обращения к кластеру; выполняет аутентификацию, авторизацию и допуск запросов	Полное управление кластером, запуск произвольных рабочих нагрузок на любом узле
Хранилище etcd	Хранит полное состояние кластера, включая конфиденциальные параметры приложений	Утрата конфиденциальности всех секретов кластера, возможность подмены его состояния
Планировщик и менеджер контроллеров	Определяют размещение рабочих нагрузок и приводят состояние кластера к заданному	Управление размещением нагрузок, размещение посторонней нагрузки на выбранном узле
Агент узла kubelet	Управляет жизненным циклом контейнеров на узле, обращается к серверу программных интерфейсов	Управление всеми контейнерами узла, доступ к их конфиденциальным параметрам
Среда исполнения контейнеров	Создаёт и исполняет контейнеры, взаимодействует с ядром операционной системы узла	Получение прав на узле, выход за границы изоляции контейнера
Рабочая нагрузка (под)	Исполняет прикладной код, располагает правами сопоставленного сервисного аккаунта	Исходная точка цепочки компрометации инфраструктуры
Реестр образов	Хранит образы, из которых создаются контейнеры	Внесение постороннего кода во все создаваемые из образа контейнеры

Между перечисленными компонентами устанавливаются границы доверия – условные рубежи, пересечение которых нарушителем означает расширение множества доступных ему активов и, как следствие, возрастание величины наступающего ущерба. В рассматриваемом объекте защиты выделяются четыре такие границы: между контейнером и узлом, на котором он исполняется; между узлом и плоскостью управления кластера; между пространствами имён, разграничивающими рабочие нагрузки различных подразделений или систем; между кластером и внешним реестром образов. Именно переходы между границами

доверия, а не отдельные несоответствия профилю безопасности, определяют развитие компрометации, что и обусловливает принятый в настоящей работе подход к построению модели объекта защиты.

1.1.3 Статистика и тенденции инцидентов безопасности в контейнерных средах

Количественные характеристики инцидентов безопасности контейнерных сред приводятся в ежегодных отраслевых исследованиях, выполняемых по опросам эксплуатирующих организаций и по данным систем мониторинга. Сводные показатели за четыре года наблюдения приведены в таблице 2.

Таблица 2 – Динамика показателей безопасности контейнерных сред по данным зарубежных отраслевых исследований

Показатель	2022	2023	2024	2025	Источник
Доля организаций, отметивших не менее одного инцидента безопасности контейнерной среды за 12 месяцев, %	93	90	89	86	[65]
Доля инцидентов, вызванных недостатком конфигурации, %	53	45	46	48	[65]
Доля инцидентов, вызванных уязвимостью образа, %	27	33	32	30	[65]
Доля организаций, задержавших развёртывание приложений из-за выявленных проблем безопасности, %	55	67	42	46	[65]
Доля предоставленных, но не используемых полномочий сервисных аккаунтов, %	84	90	98	98	[66]
Доля организаций, применяющих оркестрацию в промышленной эксплуатации, %	60	63	66	66	[67]

Приведённые в таблице 2 данные обнаруживают три устойчивые тенденции. Во-первых, доля организаций, столкнувшихся с инцидентом безопасности контейнерной среды, на всём интервале наблюдения превышает четыре пятых, то есть инцидент в такой среде является не исключительным, а ожидаемым событием. Во-вторых, недостаток конфигурации устойчиво преобладает над уязвимостью образа в качестве причины инцидента, и соотношение между ними не изменяется в пользу уязвимостей при том, что средства выявления уязвимостей образов получили за рассматриваемый период наибольшее распространение. В-третьих, доля предоставленных, но не используемых полномочий сервисных аккаунтов приближается к предельной, что означает систематическое превышение фактически необходимого объёма прав рабочих нагрузок и, как следствие, систематическое завышение величины ущерба, наступающего при компрометации отдельного контейнерного приложения.

Отечественная статистика подтверждает установленные тенденции применительно к российским организациям. Согласно данным экспертно-аналитического центра InfoWatch, число зарегистрированных утечек информации выросло с порядка 660 в 2023 году до величины, превышающей 1000 в 2024 году, при сохранении высокой доли инцидентов, в которых нарушитель действовал от имени легитимной учётной записи [69]. Аналитические отчёты об актуальных киберугрозах фиксируют, что более трети успешных атак на организации в 2024–2025 годах привели к нарушению основной деятельности, а в числе преобладающих техник указываются использование действительных учётных данных и эксплуатация недостатков конфигурации доступных из внешних сетей сервисов [70]. В банке данных угроз безопасности информации ФСТЭК России зарегистрировано 222 угрозы, из которых к средам виртуализации и контейнеризации применимы 24, в том числе угрозы выхода за пределы виртуальной машины, нарушения изоляции пользовательских данных и несанкционированного доступа к средствам управления средой виртуализации [38]. Перечисленные угрозы сформулированы для технологии виртуализации в целом и не детализированы по компонентам системы оркестрации, вследствие чего непосредственное их применение к кластеру Kubernetes требует дополнительного уточнения объектов воздействия, выполняемого в настоящей работе.

Приведённые данные позволяют заключить, что преобладающей причиной инцидентов в контейнерных средах выступает не дефект программного кода в образе приложения, а состояние конфигурации самой инфраструктуры – избыточные полномочия рабочих нагрузок, ослабленные параметры изоляции и недостаточное разграничение доступа к плоскости управления. Данное обстоятельство определяет выбор недостатков конфигурации кластера, а не уязвимостей программного обеспечения, в качестве множества, подлежащего риск-анализу в настоящей работе.

1.2 Декомпозиция кластера на активы и границы доверия

Построение модели объекта защиты выполняется путём декомпозиции кластера на активы – элементы инфраструктуры, обладающие самостоятельной ценностью и собственным набором полномочий, – и установления границ доверия между ними. Под активом в настоящей работе понимается элемент инфраструктуры контейнеризации, компрометация которого влечёт определимый ущерб и который может выступать как целью, так и промежуточным звеном действий нарушителя. Множество активов формируется по компонентам кластера, выделенным в подразделе 1.1.2, и объединяется в четыре группы: плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов. Модель объекта защиты приведена на рисунке 1.

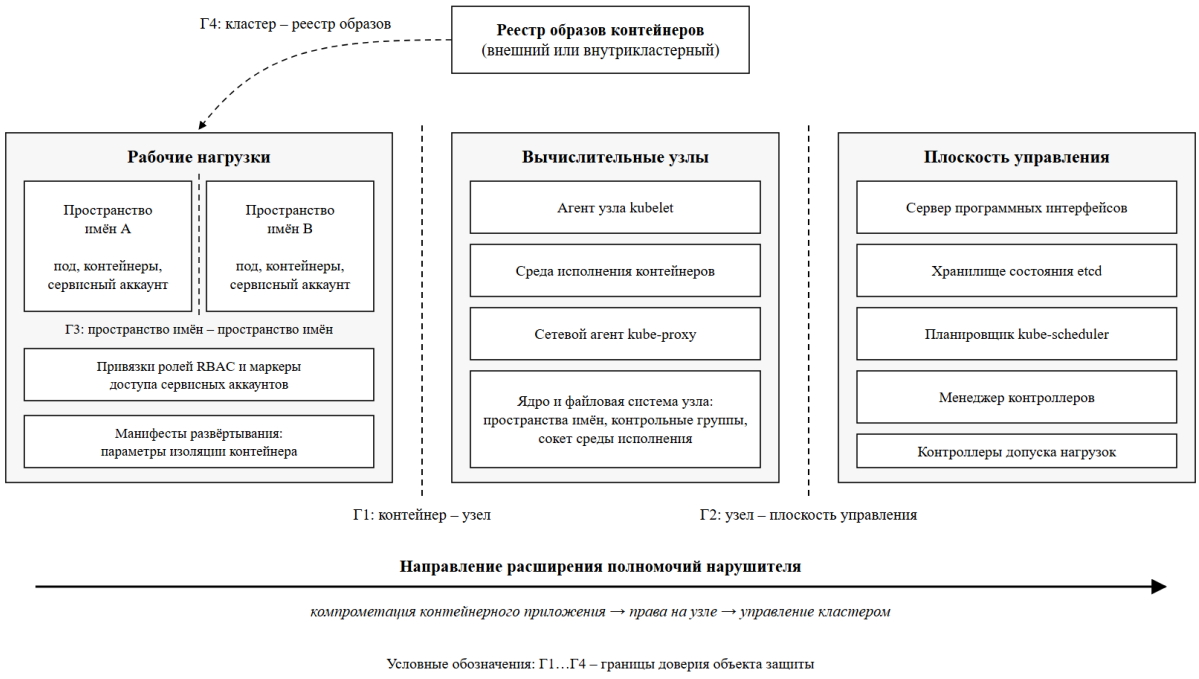


Рисунок 1 – Модель объекта защиты: декомпозиция кластера Kubernetes на активы и границы доверия

Предложенная декомпозиция обладает свойством полноты относительно принятой модели объекта защиты: каждому компоненту кластера, выделенному в таблице 1, соответствует ровно один актив, а всякий актив отнесён ровно к одной группе. Это отвечает требованию недопустимости фрагментарного и бессистемного рассмотрения проблемы [71] и обеспечивает возможность последующего

расширения множества активов при появлении новых компонентов – например, подсистемы сервисной сетки или контроллеров допуска рабочих нагрузок.

Существенной особенностью построенной модели является положение рабочей нагрузки в структуре объекта защиты. В сложившейся практике оценки защищённости контейнерных сред контейнерное приложение рассматривается как конечная цель нарушителя: обнаружение уязвимости в образе фиксируется как самостоятельный результат, а последствия ограничиваются нарушением свойств безопасности самого приложения. В настоящей работе рабочая нагрузка принимается в качестве начального звена цепочки: компрометация контейнерного приложения рассматривается как исходное событие, от которого при наличии соответствующих недостатков конфигурации становятся достижимыми узел, плоскость управления и, как следствие, все обслуживаемые кластером приложения и данные. Такое смещение исходного события позволяет включить в рассмотрение переходы между границами доверия, остающиеся вне поля зрения при пообъектной оценке.

Из принятой модели следует, что величина ущерба от компрометации отдельной рабочей нагрузки определяется не свойствами самой нагрузки, а множеством активов, достижимых при её использовании. Две рабочие нагрузки, исполняющие идентичный прикладной код, влекут различный ущерб при компрометации, если одна из них исполняется в привилегированном режиме с примонтированным каталогом узла, а вторая – с минимальным набором полномочий и ограниченным доступом к серверу программных интерфейсов. Данное положение определяет требование к разрабатываемому методическому обеспечению: единицей риск-анализа должна выступать рабочая нагрузка кластера, а не образ контейнера или обнаруженная в нём уязвимость.

1.3 Нормативное обеспечение защиты инфраструктуры контейнеризации

Требования к защите информации, обрабатываемой в автоматизированных информационных системах, частью которых выступает инфраструктура контейнеризации, установлены нормативными правовыми актами и методическими

документами ФСТЭК России, а также национальными стандартами. Приказ ФСТЭК России № 17 определяет состав мер защиты информации в государственных информационных системах, приказ № 21 – в информационных системах персональных данных, приказ № 239 – на значимых объектах критической информационной инфраструктуры [4–6]. Порядок определения угроз безопасности информации установлен методическим документом «Методика оценки угроз безопасности информации» [7], в соответствии с которым угроза описывается совокупностью нарушителя, способа реализации, объекта воздействия и наступающих последствий.

Особенности защиты информации при использовании технологий виртуализации установлены ГОСТ Р 56938-2016 [11], который вводит перечень мер защиты, применяемых к средствам виртуализации, включая разграничение доступа к средствам управления виртуальной инфраструктурой, контроль целостности образов, регистрацию событий безопасности и изоляцию вычислительных ресурсов. Классификация и правила описания уязвимостей информационных систем установлены ГОСТ Р 56545-2015 и ГОСТ Р 56546-2015 [9, 10], причём последний относит к самостоятельному классу уязвимости конфигурации, возникающие в результате задания параметров программного обеспечения, обеспечивающих возможность реализации угроз. Общие положения менеджмента риска информационной безопасности установлены ГОСТ Р ИСО/МЭК 27005-2010, ГОСТ Р ИСО 31000-2019 и ГОСТ Р 58771-2019 [14–16], определяющими риск через сочетание вероятности события и его последствий и устанавливающими перечень применимых технологий оценки риска.

Существенно, что перечисленные документы формулируют требования к защите информации в терминах мер защиты и не содержат указаний на конкретные параметры конфигурации системы оркестрации контейнерных приложений. Соответствие между требуемыми мерами защиты и параметрами кластера, посредством которых эти меры реализуются, устанавливается в настоящей работе и приведено в таблице 3.

Таблица 3 – Соответствие мер защиты информации и параметров конфигурации кластера

Мера защиты информации и её источник	**Параметр конфигурации кластера, реализующий меру**	**Последствие неприменения меры**
Идентификация и аутентификация субъектов доступа (приказ ФСТЭК России № 17, ИАФ) [4]	Запрет анонимных обращений к серверу программных интерфейсов и к агенту узла kubelet	Доступ к объектам кластера без прохождения аутентификации
Управление доступом субъектов к объектам (приказ ФСТЭК России № 17, УПД) [4]	Привязки ролей механизма RBAC, ограниченные необходимым объёмом полномочий	Обращение рабочей нагрузки к объектам кластера за пределами прикладной задачи
Регистрация событий безопасности (приказ ФСТЭК России № 17, РСБ) [4]	Политика журналирования обращений к серверу программных интерфейсов, ретенция журналов	Невозможность установления обстоятельств инцидента
Защита среды виртуализации (приказ ФСТЭК России № 17, ЗСВ; ГОСТ Р 56938-2016) [4, 11]	Запрет привилегированного режима пода, монтирования каталогов узла и пространств имён узла	Переход нарушителя с уровня контейнера на уровень узла
Обеспечение целостности информационной системы (приказ ФСТЭК России № 17, ОЦЛ) [4]	Проверка подписи образа, перечень допустимых реестров, неизменяемые идентификаторы содержимого	Исполнение постороннего кода, внесённого в образ контейнера
Защита информации при её передаче (ГОСТ Р 56938-2016) [11]	Взаимная аутентификация компонентов плоскости управления, шифрование хранимых секретов	Раскрытие конфиденциальных параметров кластера
Управление конфигурацией информационной системы (приказ ФСТЭК России № 17, УКФ) [4]	Политики допуска рабочих нагрузок, контроль изменений манифестов развёртывания	Развёртывание рабочей нагрузки с параметрами, не отвечающими требованиям защиты

Приведённое соответствие обнаруживает существенное для настоящей работы обстоятельство: всякая мера защиты информации, установленная нормативными документами применительно к инфраструктуре контейнеризации, реализуется значением одного или нескольких параметров конфигурации кластера, а неприменение меры выражается не в наличии уязвимости программного обеспечения, а в состоянии этих параметров. Тем самым нормативные требования определяют множество контролируемых параметров, но не устанавливают порядка количественного сопоставления рабочих нагрузок между собой по величине наступающего риска, что и определяет необходимость разработки собственного методического обеспечения.

1.4 Недостатки конфигурации кластера как источник киберрисков

Под недостатком конфигурации кластера в настоящей работе понимается такое штатно установленное состояние параметров рабочей нагрузки, узла, плоскости управления или реестра образов, которое повышает вероятность успешной компрометации контейнерного приложения либо величину наступающего при этом ущерба, не являясь при этом уязвимостью программного обеспечения. Принципиальным свойством недостатка конфигурации является его легитимность: привилегированный режим пода, монтирование каталога узла или расширенный набор привязок ролей представляют собой предусмотренные возможности платформы, применяемые при решении прикладных задач, и не могут быть устранены выпуском обновления. Классификация недостатков конфигурации, построенная по активам объекта защиты, приведена на рисунке 2.

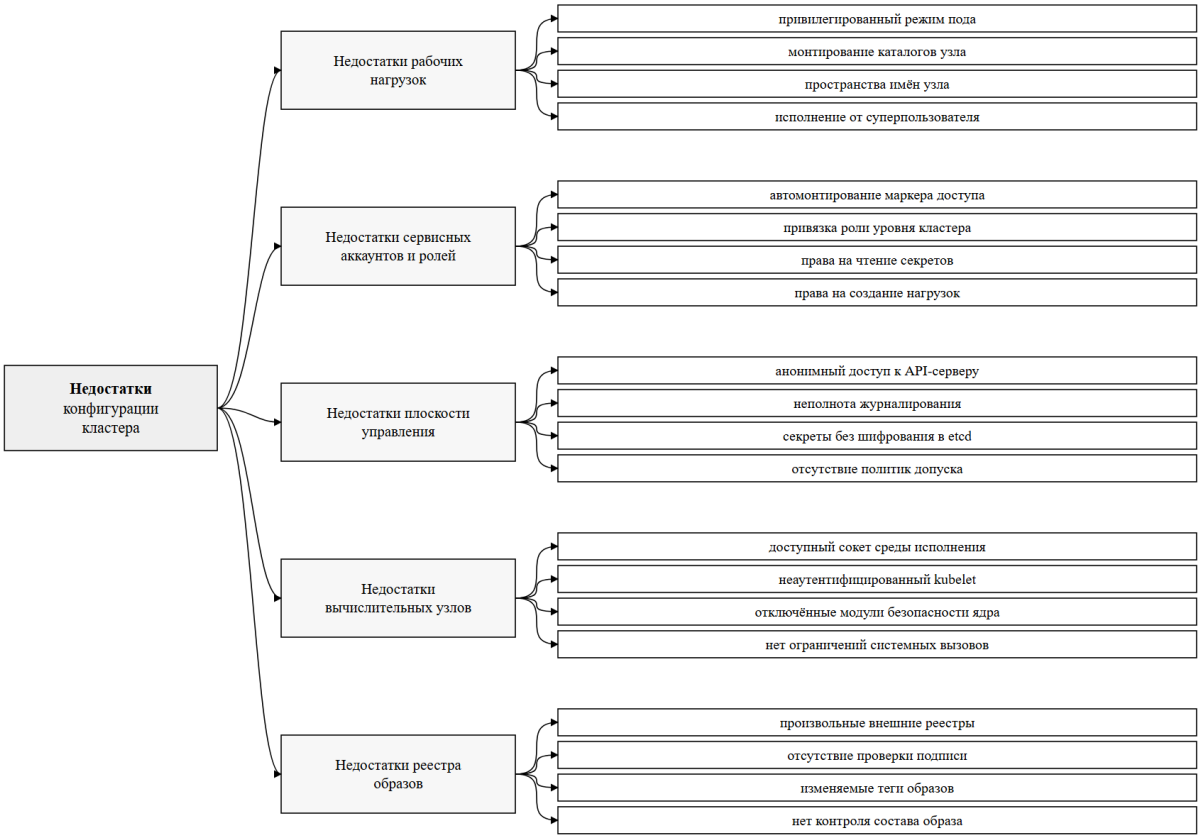


Рисунок 2 – Классификация недостатков конфигурации кластера по активам объекта защиты

Группа недостатков рабочих нагрузок объединяет параметры, ослабляющие изоляцию контейнера от узла: запуск пода в привилегированном режиме;

монтирование каталогов узла в файловую систему контейнера; использование пространств имён узла – сетевого, процессов и межпроцессного взаимодействия; предоставление контейнеру дополнительных возможностей ядра; исполнение процесса контейнера от имени суперпользователя; отсутствие запрета на повышение привилегий; доступная на запись корневая файловая система; отсутствие ограничений на потребление вычислительных ресурсов.

Группа недостатков сервисных аккаунтов и привязок ролей объединяет параметры, определяющие объём полномочий рабочей нагрузки в кластере: автоматическое монтирование маркера доступа сервисного аккаунта в поды, которым обращение к серверу программных интерфейсов не требуется; привязка роли с полномочиями уровня кластера к сервисному аккаунту прикладной нагрузки; предоставление прав на чтение конфиденциальных параметров в пределах пространства имён; предоставление прав на создание рабочих нагрузок, эквивалентных по последствиям правам администратора узла.

Группа недостатков плоскости управления объединяет параметры доступа к управляющим компонентам: допуск анонимных обращений к серверу программных интерфейсов; отсутствие или неполнота настроек журналирования обращений; отсутствие шифрования конфиденциальных параметров при хранении; доступность хранилища etcd без взаимной аутентификации сторон; отсутствие политик допуска, ограничивающих параметры создаваемых рабочих нагрузок.

Группа недостатков вычислительных узлов объединяет параметры операционной системы и среды исполнения: доступность сокета среды исполнения контейнеров из рабочей нагрузки; допуск неаутентифицированных обращений к агенту узла; отсутствие принудительного разграничения доступа средствами модулей безопасности ядра; отсутствие ограничений на перечень системных вызовов, доступных контейнеру.

Группа недостатков реестра образов объединяет параметры доверия к исполняемому коду: получение образов из внешних источников без ограничения перечня допустимых реестров; отсутствие проверки подписи образа перед его

запуском; использование изменяемых тегов образов вместо неизменяемых идентификаторов содержимого; отсутствие контроля состава образа.

Общим свойством перечисленных недостатков является отсутствие у них идентификатора уязвимости. Ни один из них не регистрируется в международных реестрах CVE и NVD, не включается в банк данных угроз безопасности информации ФСТЭК России в качестве уязвимости и не принимается на вход калькуляторами критичности, построенными для уязвимостей с присвоенным идентификатором. Вследствие этого недостатки конфигурации кластера выпадают из риск-анализа, выполняемого по сложившейся методике, хотя именно они определяют достижимость активов кластера и, следовательно, действительную величину риска.

1.5 Информационное обеспечение риск-анализа контейнерных сред

1.5.1 Базы данных уязвимостей и угроз: CVE, NVD, банк данных угроз ФСТЭК России

Международный реестр CVE обеспечивает присвоение уникальных идентификаторов общеизвестным уязвимостям программного и аппаратного обеспечения, а национальная база данных уязвимостей NVD дополняет записи реестра сведениями о характеристиках уязвимости, включая вектор и базовую оценку критичности. Банк данных угроз безопасности информации ФСТЭК России содержит сведения об уязвимостях программного обеспечения, применяемого в информационных системах Российской Федерации, и перечень угроз безопасности информации, соотнесённых с объектами воздействия и последствиями их реализации [38].

Областью определения перечисленных источников является дефект программного или аппаратного обеспечения. Запись реестра уязвимостей соотносится с конкретной версией конкретного программного продукта и устраняется выпуском обновления либо применением компенсирующей меры. Недостаток конфигурации кластера такими свойствами не обладает: он не соотносится с версией программного обеспечения, не устраняется обновлением и представляет собой результат решения, принятого при развёртывании рабочей

нагрузки. Как следствие, применение реестров уязвимостей к рассматриваемому множеству недостатков невозможно не вследствие неполноты этих реестров, а вследствие несовпадения областей определения.

Отдельно следует отметить средства количественной оценки критичности – вектор CVSS версий 3.1 и 4.0 и прогнозную оценку вероятности эксплуатации EPSS. Обе системы принимают на вход уязвимость с присвоенным идентификатором: первая исходит из характеристик самой уязвимости, вторая – из накопленной статистики наблюдаемых попыток эксплуатации. Для недостатков конфигурации кластера идентификатор отсутствует, а статистика эксплуатации не накапливается, вследствие чего непосредственное применение указанных средств неосуществимо. Подробное сопоставление калькуляторов критичности и обоснование выбранного способа переноса их метрик на контекст кластера выполняются в рамках выпускной квалификационной работы.

1.5.2 Профили безопасности NIST SP 800-190 и CIS Kubernetes Benchmark

Руководство NIST SP 800-190 по безопасности контейнерных приложений систематизирует риски контейнерной среды по пяти группам, соответствующим элементам её жизненного цикла: риски образов, риски реестров, риски систем оркестрации, риски контейнеров и риски операционной системы узла [19]. Для каждой группы приводятся характерные недостатки и рекомендуемые контрмеры. Существенно, что руководство описывает риски качественно: оно перечисляет, какие обстоятельства нежелательны и почему, но не вводит порядка количественного сопоставления рабочих нагрузок между собой.

Набор проверок CIS Kubernetes Benchmark представляет собой перечень контролируемых параметров кластера, сгруппированных по компонентам плоскости управления, хранилищу etcd, настройкам плоскости управления, вычислительным узлам и политикам [25]. Каждая проверка формулируется как требование к значению параметра и сопровождается порядком его установления и исправления. Результатом применения набора проверок является дискретная оценка соответствия: параметр либо удовлетворяет требованию, либо нет. Перевод полученной оценки в

меру риска набором проверок не предусмотрен, равно как не предусмотрен и учёт совместного влияния нескольких несоответствий.

Тем самым оба источника обеспечивают полноту перечня недостатков конфигурации, но не обеспечивают их количественного сопоставления. Именно это обстоятельство определяет их роль в настоящей работе: они принимаются в качестве источника множества недостатков, подлежащих учёту, тогда как порядок присвоения этим недостаткам количественных оценок разрабатывается самостоятельно.

1.5.3 Матрица MITRE ATT&CK for Containers

Матрица MITRE ATT&CK for Containers систематизирует техники, применяемые нарушителем в контейнерной инфраструктуре, распределяя их по тактикам – целям, преследуемым нарушителем на соответствующем этапе [43, 44]. В отличие от реестров уязвимостей, матрица описывает не дефект, а способ действия, вследствие чего она применима к недостаткам конфигурации: техника соотносится с тем состоянием инфраструктуры, которое делает её осуществимой. Перечень техник, эксплуатирующих выделенные недостатки конфигурации кластера, приведён в таблице 4.

Таблица 4 – Техники матрицы MITRE ATT&CK for Containers, эксплуатирующие недостатки конфигурации кластера

Идентификатор	**Наименование техники**	**Тактика**	**Эксплуатируемый недостаток конфигурации**
T1610	Deploy Container	Execution, Defense Evasion	Права сервисного аккаунта на создание рабочих нагрузок
T1611	Escape to Host	Privilege Escalation	Привилегированный режим пода, монтирование каталогов узла
T1609	Container Administration Command	Execution	Доступность сокета среды исполнения из рабочей нагрузки
T1613	Container and Resource Discovery	Discovery	Права сервисного аккаунта на чтение объектов кластера
T1552.007	Unsecured Credentials: Container API	Credential Access	Автоматическое монтирование маркера доступа сервисного аккаунта
T1525	Implant Internal Image	Persistence	Отсутствие проверки подписи образа, изменяемые теги
T1612	Build Image on Host	Defense Evasion	Доступность среды исполнения узла из рабочей нагрузки
T1496	Resource Hijacking	Impact	Отсутствие ограничений на потребление ресурсов

Идентификатор	Наименование техники	Тактика	Эксплуатируемый недостаток конфигурации
T1078	Valid Accounts	Persistence, Privilege Escalation	Избыточные привязки ролей, неотозванные полномочия

Приведённое сопоставление показывает, что всякому выделенному недостатку конфигурации соответствует наблюдаемая техника его эксплуатации, а всякой технике – определимое последствие. Это обстоятельство позволяет принять пару «недостаток конфигурации – техника эксплуатации» в качестве элементарной единицы описания и положить её в основание базы знаний, формирование которой составляет содержание дальнейшего исследования.

Сопоставление рассмотренных источников информационного обеспечения риск-анализа приведено в таблице 5.

Таблица 5 – Сопоставление источников информационного обеспечения риск-анализа контейнерных сред

Источник	Что описывает	Применимость к недостаткам конфигурации кластера
CVE, NVD	Дефекты программного обеспечения с присвоенным идентификатором	Неприменим: недостаток конфигурации идентификатора не получает
Банк данных угроз ФСТЭК России	Уязвимости применяемого программного обеспечения и перечень угроз	Применим частично: угрозы соотносятся с объектами воздействия, уязвимости – нет
NIST SP 800-190	Риски контейнерной среды по элементам жизненного цикла	Применим как источник перечня недостатков; количественной оценки не даёт
CIS Kubernetes Benchmark	Контролируемые параметры кластера и требования к их значениям	Применим как источник перечня проверок; даёт дискретную оценку соответствия
MITRE ATT&CK for Containers	Техники действий нарушителя в контейнерной инфраструктуре	Применим: техника соотносится с состоянием конфигурации, делающим её осуществимой
CVSS 3.1, CVSS 4.0, EPSS	Количественные оценки критичности уязвимостей	Непосредственно неприменим: требует идентификатора и статистики эксплуатации

1.6 Анализ существующих средств анализа защищённости контейнерных сред

Практическая оценка защищённости контейнерных сред выполняется специализированными средствами, реализующими проверку объектов кластера на

соответствие профилю безопасности, анализ состава образов и контроль поведения среды исполнения. Результаты сравнительного анализа наиболее распространённых средств приведены в таблице 6.

Таблица 6 – Сравнительный анализ средств анализа защищённости контейнерных сред

Средство	Что обеспечивает	Чего не обеспечивает
kube-bench	Проверку параметров кластера на соответствие набору CIS Kubernetes Benchmark	Не переводит несоответствие в меру риска, не учитывает связность недостатков
Kubescape	Проверку объектов кластера по нескольким профилям, сопоставление с техниками матрицы ATT&CK	Оценивает каждый объект изолированно, не вычисляет достижимость активов
Trivy	Выявление уязвимостей образов и ошибок в манифестах рабочих нагрузок	Ограничен уязвимостями с идентификаторами; ущерб от компрометации не оценивает
Falco	Обнаружение аномального поведения среды исполнения по правилам	Фиксирует отдельное событие, не связывая его с мерой риска рабочей нагрузки

Выполненный анализ позволяет установить четыре обстоятельства, общих для всех рассмотренных средств. Во-первых, результатом их работы является дискретная оценка соответствия – перечень выявленных несоответствий профилю безопасности либо перечень обнаруженных уязвимостей, – но не мера риска, определяемая произведением ущерба на вероятность его наступления. Во-вторых, проверка носит пообъектный характер: каждый объект кластера оценивается изолированно, вследствие чего сочетаемость недостатков, образующих цепочку перехода между границами доверия, остаётся вне рассмотрения. В-третьих, недостатки конфигурации, не обладающие идентификаторами уязвимостей, не получают количественной оценки критичности и приводятся в отчётах с качественными пометками, не допускающими сопоставления рабочих нагрузок между собой. В-четвёртых, обследование выполняется разово либо по расписанию и не предусматривает переоценки состояния при изменении состава рабочих нагрузок, версий образов и политик доступа, вследствие чего полученные результаты устаревают вместе с изменением конфигурации кластера.

Перечисленные обстоятельства образуют содержание противоречий, положенных в основу настоящего исследования, и определяют состав разрабатываемого методического, алгоритмического и программного обеспечения.

1.7 Дерево угроз и индуцированных ими рисков инфраструктуры контейнеризации

Выделенные недостатки конфигурации порождают угрозы безопасности информации, каждая из которых индуцирует свою цепочку рисков. Дерево угроз и индуцированных ими рисков, построенное для инфраструктуры контейнеризации Kubernetes, приведено на рисунке 3.

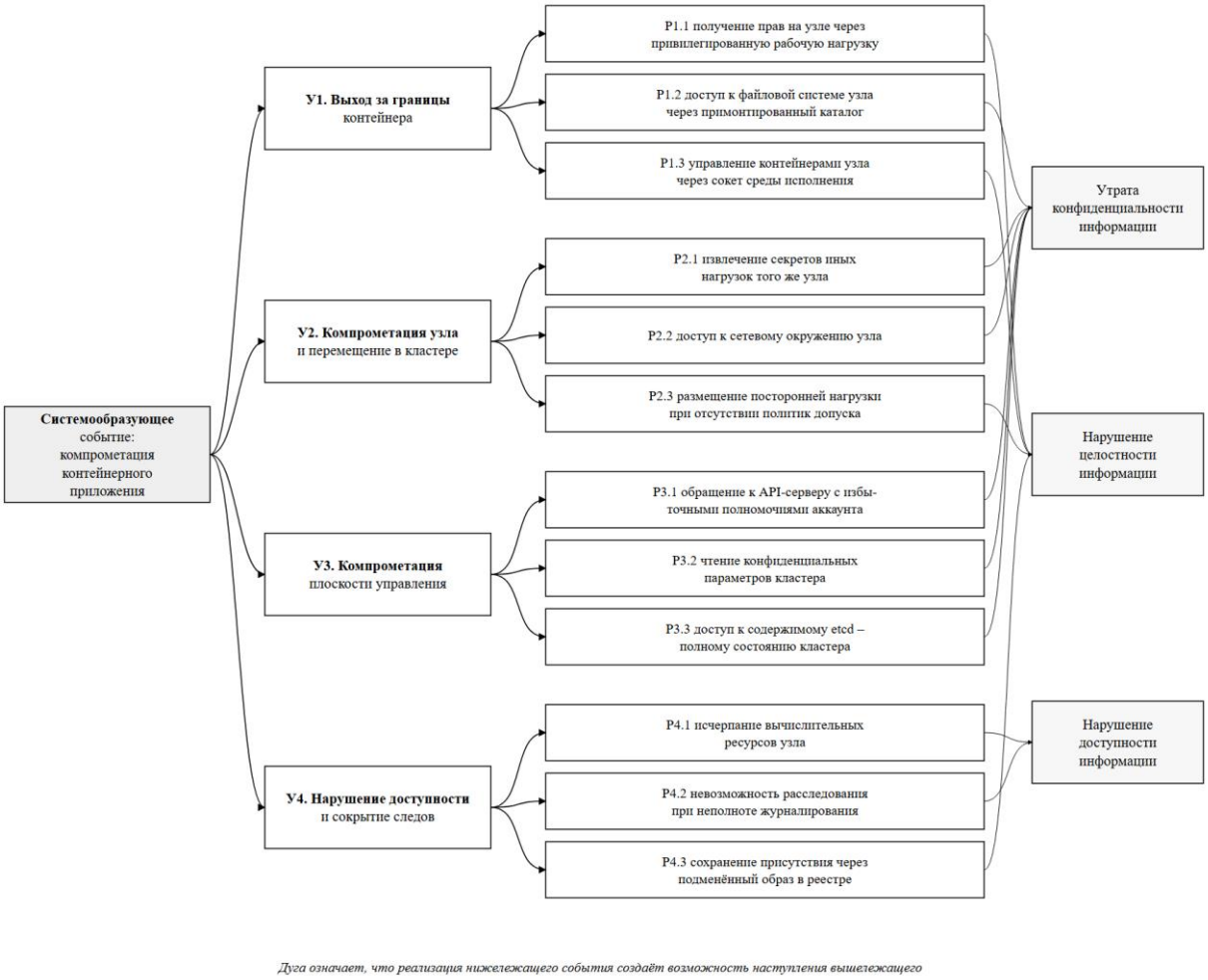


Рисунок 3 – Дерево угроз и индуцированных ими рисков инфраструктуры контейнеризации Kubernetes

Системообразующим событием построенного дерева является компрометация контейнерного приложения, от которой разветвляются четыре угрозы,

соответствующие последовательным этапам действий нарушителя и пересекаемым им границам доверия.

– угроза У1 – выход за границы контейнера – реализуется техниками тактики повышения привилегий и индуцирует цепочку рисков: Р1.1 – получение прав на узле через рабочую нагрузку, исполняемую в привилегированном режиме; Р1.2 – доступ к файловой системе узла через примонтированный каталог; Р1.3 – управление контейнерами узла через доступный сокет среды исполнения;

– угроза У2 – компрометация вычислительного узла и перемещение внутри кластера – индуцирует цепочку рисков: Р2.1 – извлечение конфиденциальных параметров иных рабочих нагрузок, размещённых на том же узле; Р2.2 – доступ к сетевому окружению узла при использовании сетевого пространства имён узла; Р2.3 – размещение посторонней рабочей нагрузки при отсутствии политик допуска;

– угроза У3 – компрометация плоскости управления – индуцирует цепочку рисков: Р3.1 – обращение к серверу программных интерфейсов с полномочиями сервисного аккаунта, превышающими необходимые; Р3.2 – чтение конфиденциальных параметров кластера; Р3.3 – доступ к содержимому хранилища etcd, эквивалентный получению полного состояния кластера;

– угроза У4 – нарушение доступности и сокрытие следов – индуцирует цепочку рисков: Р4.1 – исчерпание вычислительных ресурсов узла при отсутствии ограничений на их потребление; Р4.2 – невозможность расследования инцидента при неполноте журналирования обращений к серверу программных интерфейсов; Р4.3 – сохранение присутствия нарушителя через подменённый образ в реестре.

Построенное дерево допускает формальное описание. Его вершинами нижнего уровня служат недостатки конфигурации, выделенные на рисунке 2, вершинами промежуточного уровня – индуцируемые ими угрозы, вершинами верхнего уровня – риски утраты конфиденциальности, целостности и доступности обслуживаемых кластером приложений и данных; дуга между вершинами означает, что реализация нижележащего события создаёт возможность наступления вышележащего. Путь от недостатка конфигурации к риску верхнего уровня образует сценарий компрометации, которому соответствует последовательность техник матрицы

ATT&CK for Containers. Мера риска отдельного сценария, в соответствии с принятым определением, есть произведение величины ущерба, наступающего при его реализации, на вероятность его реализации, а мера риска рабочей нагрузки определяется совокупностью реализуемых для неё сценариев. Существенно, что сценарии не являются несовместными: одна и та же рабочая нагрузка может быть скомпрометирована несколькими способами, а достигаемый при этом ущерб для разных сценариев частично совпадает, вследствие чего простое суммирование мер риска приводит к завышенной оценке. Порядок агрегирования, устраняющий это завышение, устанавливается в рамках дальнейшего исследования.

Построенное дерево согласуется с порядком, установленным методикой оценки угроз безопасности информации [7], в соответствии с которым угроза описывается совокупностью нарушителя, способа реализации, объекта воздействия и наступающих последствий. Отличие состоит в выборе объекта воздействия: методика относит к объектам воздействия компоненты информационной системы – программное обеспечение, средства вычислительной техники, каналы связи, – тогда как в настоящей работе объектом воздействия выступает актив кластера, а достигаемый ущерб определяется множеством активов, достижимых при компрометации исходной рабочей нагрузки. Такое уточнение перечня объектов воздействия применительно к конкретной информационной системе методикой допускается, однако требует самостоятельного определения характеризующих объект показателей, что выполняется в рамках дальнейшего исследования.

Существенной особенностью построенного дерева является то, что переход от угрозы к риску в нём обусловлен не наличием уязвимости, а состоянием конфигурации кластера. Так, риск Р1.1 реализуется лишь для тех рабочих нагрузок, которым разрешено исполнение в привилегированном режиме, а риск Р3.1 – лишь для тех, сервисный аккаунт которых располагает полномочиями, превышающими необходимые для решения прикладной задачи. Тем самым дерево угроз оказывается не универсальным описанием, а функцией от фактического состава рабочих нагрузок и предоставленных им полномочий, что и обусловливает необходимость

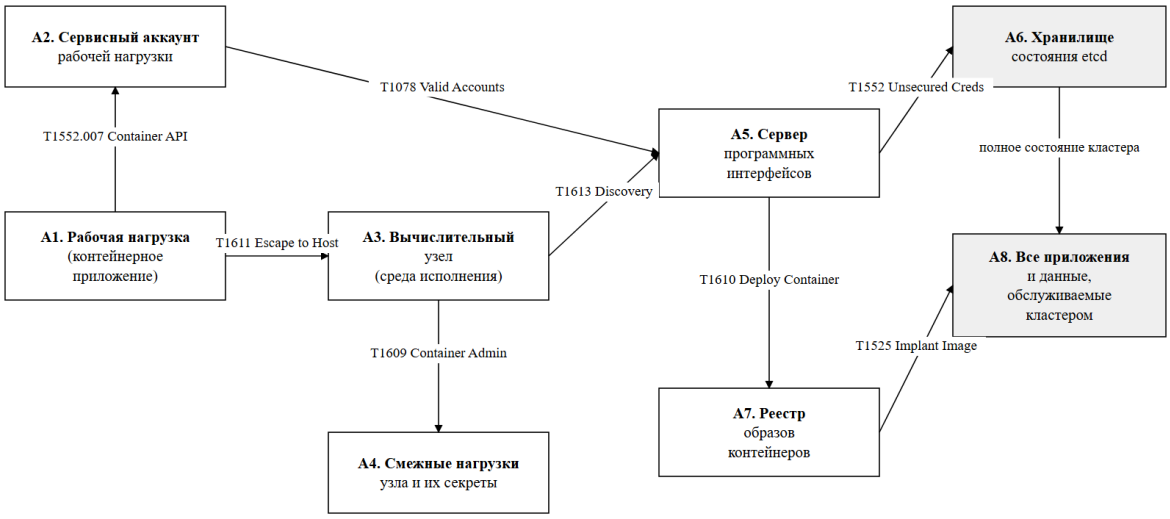
его пересчёта при каждом изменении конфигурации, реализуемого разрабатываемой интеллектуальной системой.

Построенное дерево применимо ко всем выделенным группам активов, однако состав реализуемых цепочек рисков для них различен. Для рабочих нагрузок, обслуживающих внешние обращения, характерны цепочки, начинающиеся с компрометации прикладного кода и продолжающиеся выходом за границы контейнера. Для нагрузок, располагающих полномочиями управления объектами кластера, определяющими являются цепочки, ведущие непосредственно к плоскости управления, минуя компрометацию узла. Для системных нагрузок, размещаемых на всех узлах кластера, характерна цепочка, в которой компрометация единственного экземпляра влечёт последствия для всей инфраструктуры. Данное различие подтверждает, что оценка риска должна выполняться применительно к конкретной рабочей нагрузке, а не к кластеру в целом, и обосновывает выбор рабочей нагрузки в качестве единицы риск-анализа.

1.8 Риск-ландшафт инфраструктуры контейнеризации

Построенное дерево угроз определяет состав индуцированных рисков, но не устанавливает их количественного соотношения между собой. Переход от дерева к риск-ландшафту объекта защиты выполняется в два действия: сначала множество активов кластера представляется графом достижимости, пути в котором образуют сценарии компрометации, затем каждому сценарию ставится в соответствие мера риска, определяемая в соответствии с принятым определением как произведение величины ожидаемого ущерба на вероятность его наступления [71].

Граф достижимости активов кластера строится на множестве активов, выделенных при декомпозиции объекта защиты. Вершинами графа выступают активы, дугами – переходы между ними, становящиеся осуществимыми при наличии соответствующего недостатка конфигурации; каждая дуга размечается техникой матрицы MITRE ATT&CK for Containers, посредством которой переход реализуется [44]. Граф достижимости приведён на рисунке 4.



Путь в графе от A1 к A8 образует сценарий компрометации; дуги размечены техниками MITRE ATT&CK for Containers

Рисунок 4 – Граф достижимости активов кластера с разметкой переходов техниками матрицы MITRE ATT&CK for Containers

Сценарием компрометации называется путь в графе достижимости, начинающийся в вершине A1 – скомпрометированном контейнерном приложении – и оканчивающийся в вершине, соответствующей целевому активу. Такое определение сценария согласуется с принятой моделью объекта защиты, в которой компрометация рабочей нагрузки выступает начальным, а не конечным событием, и позволяет учитывать взаимное усиление недостатков конфигурации: сочетание двух недостатков, каждый из которых в отдельности допускает переход лишь через одну границу доверия, образует путь, ведущий к плоскости управления.

Вероятность реализации сценария определяется как произведение вероятностей переходов, образующих путь, в предположении их условной независимости при заданном состоянии конфигурации. Вероятность отдельного перехода принимается равной оценке осуществимости соответствующей техники при наличии недостатка конфигурации и определяется экспертным путём с последующим уточнением по накопленной статистике; величина ущерба нормируется на интервале от нуля до единицы относительно ущерба, наступающего при компрометации всего кластера, и определяется составом активов, достижимых

по данному пути. Мера риска сценария вычисляется как произведение полученных величин.

Значения показателей для десяти типовых сценариев компрометации кластера, сформированных по графу достижимости, приведены в таблице 7. Приведённые значения получены экспертным путём и носят иллюстративный характер: они демонстрируют порядок расчёта и соотношение сценариев между собой, тогда как значения для конкретного кластера определяются его фактической конфигурацией и подлежат уточнению разрабатываемым методическим обеспечением.

Таблица 7 – Риск-ландшафт инфраструктуры контейнеризации: типовые сценарии компрометации и их мера риска

Обозначение	Сценарий компрометации (путь в графе достижимости)	Эксплуатируемый недостаток конфигурации	Техника	P	U	R	Уровень
C1	A1 → A3 → A5 → A6: выход на узел, обращение к плоскости управления, доступ к etcd	Привилегированный режим пода, избыточные права сервисного аккаунта	T1611, T1613, T1552	0,80	0,90	0,72	критический
C2	A1 → A2 → A5 → A8: использование маркера доступа сервисного аккаунта, развёртывание посторонней нагрузки	Автомонтирование маркера, права на создание нагрузок	T1552.007, T1610	0,70	0,90	0,63	критический
C3	A1 → A3 → A4: выход на узел через сокет среды исполнения, извлечение секретов смежных нагрузок	Доступность сокета среды исполнения из рабочей нагрузки	T1609, T1552	0,75	0,72	0,54	критический
C4	A1 → A3 → A5: компрометация узла и обращение к серверу программных интерфейсов от имени агента узла	Монтирование каталогов узла, неаутентифицированный доступ к kubelet	T1611, T1613	0,60	0,75	0,45	высокий
C5	A1 → A7 → A8: подмена образа в реестре и его развёртывание на всех узлах кластера	Отсутствие проверки подписи образа, изменяемые теги	T1525	0,45	0,85	0,38	высокий
C6	A1 → A2 → A5: обращение к плоскости управления с полномочиями, превышающими необходимые	Привязка роли уровня кластера к прикладной нагрузке	T1078	0,50	0,60	0,30	высокий

Обозначение	Сценарий компрометации (путь в графе достижимости)	Эксплуатируемый недостаток конфигурации	Техника	P	U	R	Уровень
C7	A1 → A3 → A4: доступ к сетевому окружению узла при использовании сетевого пространства имён узла	Пространства имён узла, отсутствие сетевых политик	T1613	0,40	0,60	0,24	средний
C8	A1 → A3: получение прав на узле без дальнейшего перемещения	Исполнение процесса от имени суперпользователя, отсутствие запрета повышения привилегий	T1611	0,45	0,40	0,18	средний
C9	A1 → A3: исчерпание вычислительных ресурсов узла	Отсутствие ограничений на потребление ресурсов	T1496	0,60	0,20	0,12	низкий
C10	A1: сокрытие следов присутствия в пределах скомпрометированной нагрузки	Неполнота журналирования, короткая ретенция журналов	T1070	0,40	0,20	0,08	низкий

Распределение сценариев по величине меры риска, образующее риск-ландшафт инфраструктуры контейнеризации, приведено на рисунке 5.

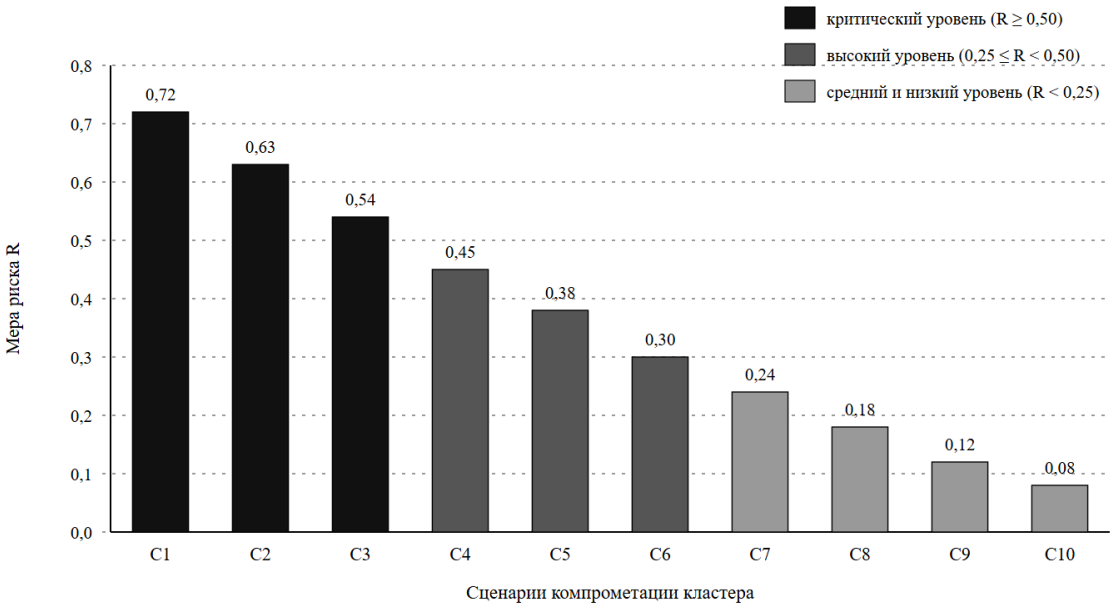


Рисунок 5 – Риск-ландшафт инфраструктуры контейнеризации: распределение сценариев компрометации по величине меры риска

Построенный риск-ландшафт допускает содержательное истолкование. Три сценария, отнесённые к критическому уровню, объединены общим признаком: все они оканчиваются в активах, принадлежащих плоскости управления либо позволяющих получить конфиденциальные параметры иных рабочих нагрузок, то есть влекут ущерб, не ограниченный скомпрометированным приложением. При этом ни один из них не требует эксплуатации уязвимости программного обеспечения: каждый реализуется штатными средствами платформы при соответствующем состоянии конфигурации. Сценарии низкого уровня, напротив, ограничены пределами скомпрометированной рабочей нагрузки и её узла. Тем самым величина риска определяется не тяжестью отдельного недостатка, а протяжённостью пути, который этот недостаток открывает в графе достижимости.

Существенным свойством риск-ландшафта является его зависимость от текущего состава рабочих нагрузок и предоставленных им полномочий: изменение манифеста единственной нагрузки способно как исключить сценарий из множества реализуемых, так и образовать новый путь к целевому активу. Из этого следует, что риск-ландшафт не может быть построен однократно и должен пересчитываться при каждом изменении конфигурации кластера, что и определяет требование непрерывности к разрабатываемой интеллектуальной системе.

1.9 Выявление противоречий и постановка задач исследования

Выполненный анализ информационного обеспечения риск-анализа контейнерных сред, существующих средств анализа защищённости и построенный риск-ландшафт объекта защиты позволяют перейти к выявлению противоречий, разрешение которых составляет содержание настоящего исследования. Противоречие формулируется как несоответствие между объективной потребностью риск-анализа инфраструктуры контейнеризации и возможностями существующих методов и средств, установленными в подразделах 1.5 и 1.6.

Первое противоречие следует из принятой модели объекта защиты (подраздел 1.2): величина ущерба определяется множеством активов, достижимых при компрометации рабочей нагрузки, тогда как сложившаяся практика оценивает

защищённость по отдельным образам и обнаруженным в них уязвимостям, считая компрометацию приложения конечным событием. Второе противоречие установлено при анализе информационного обеспечения (подраздел 1.5.1): недостатки конфигурации кластера не получают идентификатора и не регистрируются в реестрах уязвимостей, ориентированных на дефекты программного кода. Третье противоречие вытекает оттуда же: калькуляторы критичности CVSS и EPSS принимают на вход уязвимость с присвоенным идентификатором и накопленной статистикой эксплуатации, отсутствующими у конфигурационных недостатков. Четвёртое противоречие установлено при анализе средств анализа защищённости (подраздел 1.6) и подтверждено построенным риск-ландшафтом (подраздел 1.8): риск определяется протяжённостью пути в графе достижимости, тогда как проверки существующих средств носят пообъектный характер. Пятое противоречие следует из установленной зависимости риск-ландшафта от текущего состава рабочих нагрузок: действующие методики предполагают разовое обследование по фиксированному профилю соответствия.

Каждому выявленному противоречию ставится в соответствие одна задача исследования, решение которой даёт один результат, выносимый на защиту. Соответствие противоречий, задач и результатов приведено в таблице 8; полный вид матрицы целеполагания, включающий новизну, практическую и теоретическую ценность каждого результата, приведён в приложении Б.

Таблица 8 – Соответствие противоречий, задач и результатов исследования

№	Противоречие (в сокращённой формулировке)	Задача исследования	Результат, выносимый на защиту
1	Между необходимостью рассматривать кластер как связную систему активов с различными границами доверия и практикой оценки защищённости по отдельным образам и их уязвимостям	Декомпозиция инфраструктуры контейнеризации на активы и границы доверия и построение дерева угроз и индуцированных ими рисков	Модель объекта защиты и построенное на ней дерево угроз и индуцированных рисков
2	Между потребностью в едином описании недостатков конфигурации кластера и ориентированностью баз данных уязвимостей на дефекты программного кода	Формирование базы знаний соответствий недостатков конфигурации и эксплуатирующих их техник с привязкой каждой пары к наступающему ущербу	База знаний троек «недостаток конфигурации – эксплуатирующая техника – наступающий ущерб»
3	Между необходимостью	Разработка методики	Методика и реализующий

№	Противоречие (в сокращённой формулировке)	Задача исследования	Результат, выносимый на защиту
	количественного выражения критичности недостатков конфигурации и применимостью калькуляторов CVSS и EPSS только к уязвимостям с идентификатором	количественной оценки вероятности успешной компрометации контейнерного приложения и величины наступающего ущерба	её алгоритм расчёта меры риска компрометации контейнерного приложения
4	Между необходимостью учёта сочетаемости недостатков, образующих цепочки перехода между границами доверия, и пообъектным характером проверок средств анализа защищённости	Формирование типовых сценариев компрометации в виде путей достижимости активов и построение риск-ландшафта кластера	Множество сценариев компрометации и риск-ландшафт инфраструктуры контейнеризации
5	Между потребностью в удержании оценки риска в актуальном состоянии при изменении конфигурации и статичностью действующих методик разового обследования	Создание интеллектуальной системы оценки и регулирования киберрисков кластера и формирование комплекса мер риск-регулирования	Программное обеспечение интеллектуальной системы и комплекс мер регулирования риск-ландшафта

Выполненное сопоставление показывает, что число выявленных противоречий, число поставленных задач и число выносимых на защиту результатов совпадает и равно пяти, чем обеспечивается требуемая методическими рекомендациями согласованность целеполагания [71]. Ни одна из поставленных задач не сводится к ознакомлению с предметной областью либо изучению существующих решений: каждая предполагает действие с определимым результатом – декомпозицию, формирование, разработку, построение или создание.

1.10 Формирование требований к методическому, алгоритмическому и программному обеспечению

Поставленные задачи определяют состав разрабатываемого обеспечения и предъявляемые к нему требования. Требования формулируются исходя из установленных недостатков существующих средств анализа защищённости контейнерных сред и из свойств объекта защиты, выявленных при построении его модели и риск-ландшафта. Состав требований приведён в таблице 9.

Таблица 9 – Требования к методическому, алгоритмическому и программному обеспечению интеллектуальной системы

Обозначение	Содержание требования	Обоснование требования

Обозначение	Содержание требования	Обоснование требования
Тр1	Единицей риск-анализа выступает рабочая нагрузка кластера, а не образ контейнера и не обнаруженная в нём уязвимость	Величина ущерба определяется множеством активов, достижимых при компрометации нагрузки (подраздел 1.2)
Тр2	Обеспечение принимает на вход недостатки конфигурации, не обладающие идентификаторами уязвимостей, и ставит им в соответствие технику эксплуатации и наступающий ущерб	Недостатки конфигурации не регистрируются в реестрах уязвимостей (подраздел 1.5.1)
Тр3	Результатом оценки является мера риска как произведение вероятности наступления ущерба на его величину, а не дискретная оценка соответствия профилю	Существующие средства дают оценку соответствия и не переводят её в меру риска (подраздел 1.6)
Тр4	Оценка учитывает сочетаемость недостатков конфигурации, образующих пути в графе достижимости активов	Проверки существующих средств носят пообъектный характер (подраздел 1.6)
Тр5	Риск-ландшафт пересчитывается при изменении состава рабочих нагрузок, версий образов и политик доступа без повторного обследования кластера вручную	Действующие методики предполагают разовое обследование по фиксированному профилю (подраздел 1.6)
Тр6	Классификация рабочих нагрузок по уровню риска выполняется обученной моделью по совокупности параметров манифеста	Требуется сопоставление нагрузок между собой при отсутствии статистики эксплуатации (подразделы 1.5.1, 1.8)
Тр7	Меры риск-регулирования классифицируются по масштабности и профильности и оцениваются величиной достигаемого снижения меры риска	Требование третьего такта методических рекомендаций [71] (раздел 2)
Тр8	Множество контролируемых параметров кластера покрывает меры защиты информации, установленные нормативными документами	Соответствие мер защиты и параметров конфигурации (подраздел 1.3)

Сформулированные требования определяют облик разрабатываемого обеспечения и служат критериями оценки полученных результатов. Требования Тр1–Тр4 относятся к методическому обеспечению и реализуются базой знаний, методикой количественной оценки и порядком построения сценариев; требования Тр5 и Тр6 относятся к алгоритмическому и программному обеспечению интеллектуальной системы; требования Тр7 и Тр8 относятся к комплексу мер риск-регулирования, формируемому во втором разделе настоящей работы.

1.11 Выводы по первому разделу

Выполненное в настоящем разделе исследование инфраструктуры контейнеризации Kubernetes как объекта защиты, информационного обеспечения риск-анализа контейнерных сред и существующих средств анализа защищённости позволило получить следующие результаты.

– построена модель инфраструктуры контейнеризации как объекта защиты, включающая четыре группы активов – плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов – и четыре границы доверия между ними; установлено, что величина ущерба от компрометации рабочей нагрузки определяется множеством активов, достижимых при её использовании, а не свойствами самой нагрузки;

– обосновано положение рабочей нагрузки в качестве начального, а не конечного звена цепочки компрометации, что позволяет включить в рассмотрение переходы между границами доверия, остающиеся вне поля зрения при пообъектной оценке защищённости;

– предложена классификация недостатков конфигурации кластера по активам объекта защиты, объединяющая пять групп – недостатки рабочих нагрузок, сервисных аккаунтов и привязок ролей, плоскости управления, вычислительных узлов и реестра образов – и обладающая свойством полноты относительно принятой модели объекта защиты;

– установлено, что международные реестры уязвимостей CVE и NVD, банк данных угроз безопасности информации ФСТЭК России и калькуляторы критичности CVSS и EPSS имеют своей областью определения дефект программного обеспечения и непосредственно неприменимы к недостаткам конфигурации кластера, вследствие чего множество недостатков должно формироваться по руководству NIST SP 800-190 и набору проверок CIS Kubernetes Benchmark, а способ их эксплуатации – по матрице MITRE ATT&CK for Containers;

– выполнен сравнительный анализ средств анализа защищённости контейнерных сред, показавший, что kube-bench, Kubescape, Trivy и Falco дают дискретную оценку соответствия профилю безопасности, оценивают объекты

кластера изолированно, не присваивают количественной оценки недостаткам без идентификатора уязвимости и не предусматривают переоценки состояния при изменении конфигурации;

– построено дерево угроз и индуцированных ими рисков инфраструктуры контейнеризации, системообразующим событием которого является компрометация контейнерного приложения, содержащее четыре угрозы и двенадцать индуцированных рисков и допускающее формальное описание, в котором путь от недостатка конфигурации к риску верхнего уровня образует сценарий компрометации.

– установлено соответствие между мерами защиты информации, предусмотренными приказами ФСТЭК России и национальными стандартами, и параметрами конфигурации кластера, посредством которых эти меры реализуются, чем определено множество контролируемых параметров объекта защиты;

– построен риск-ландшафт инфраструктуры контейнеризации: сформирован граф достижимости активов кластера, выделены десять типовых сценариев компрометации и для каждого вычислена мера риска как произведение вероятности наступления ущерба на его величину, что позволило упорядочить сценарии по величине риска и установить, что сценарии критического уровня не требуют эксплуатации уязвимостей программного обеспечения;

– выявлены пять противоречий, поставлены пять задач исследования, сформулированы пять выносимых на защиту результатов и сформированы восемь требований к разрабатываемому методическому, алгоритмическому и программному обеспечению.

Полученные результаты обосновывают постановку задач исследования. Установленная неприменимость реестров уязвимостей к недостаткам конфигурации кластера определяет необходимость формирования базы знаний соответствий недостатков конфигурации и эксплуатирующих их техник с привязкой каждой пары к наступающему ущербу. Отсутствие количественной оценки критичности у недостатков без идентификатора уязвимости определяет необходимость разработки методики количественной оценки вероятности успешной компрометации

контейнерного приложения и величины наступающего ущерба. Пообъектный характер существующих проверок определяет необходимость формирования типовых сценариев компрометации в виде путей достижимости активов. Статичность действующих методик определяет необходимость создания интеллектуальной системы, выполняющей классификацию рабочих нагрузок по уровню риска и пересчёт риск-ландшафта при смене снимка конфигурации. Выработка мер риск-регулирования, приводящих меру риска к допустимым значениям, составляет содержание второго раздела настоящей работы.

2 Комплекс мер риск-регулирования инфраструктуры контейнеризации

Построенное в первом разделе дерево угроз и полученный риск-ландшафт объекта защиты образуют первые два такта исследования, предусмотренные методическими рекомендациями по выполнению работ в области обеспечения информационной безопасности, – построение дерева угроз и индуцированных ими рисков и оценку этих рисков [71]. Настоящий раздел посвящён третьему такту – выработке мер риск-регулирования, приводящих меру риска к допустимым значениям. В соответствии с указанными рекомендациями меры классифицируются по масштабности и по профильности, а их состав определяется не общими соображениями, а сценариями компрометации, выявленными при построении риск-ландшафта.

2.1 Классификация мер риск-регулирования по масштабности и профильности

Под мерой риск-регулирования понимается действие, изменяющее значение вероятности наступления ущерба либо величину этого ущерба и, как следствие, меру риска. Классификация мер выполняется по двум основаниям. По масштабности выделяются меры надгосударственного, государственного, корпоративного и личного уровня; по профильности – меры организационно-правовые, технические и прочие, к которым относятся меры кадрового и образовательного характера. Состав мер, применимых к инфраструктуре контейнеризации, приведён в таблице 10.

Таблица 10 – Классификация мер риск-регулирования инфраструктуры контейнеризации

Масштабность	Организационно-правовые меры	Технические меры	Прочие меры
Надгосударственный уровень	Применение международных стандартов ISO/IEC 27002 и ISO/IEC 27005, руководств NIST SP 800-190 и SP 800-53 при формировании корпоративных требований [17–19, 88]	Участие в международных программах регистрации уязвимостей и обмена сведениями об угрозах (CVE, NVD, MITRE ATT&CK, MITRE D3FEND) [39, 40, 43, 90]	Участие специалистов в отраслевых рабочих группах по безопасности облачных технологий [29]

Масштабность	Организационно-правовые меры	Технические меры	Прочие меры
Государственный уровень	Выполнение требований приказов ФСТЭК России № 17, 21 и 239 и методического документа по оценке угроз безопасности информации [4–7]	Применение банка данных угроз безопасности информации ФСТЭК России и сертифицированных средств защиты информации, применимых к средам виртуализации [11, 38]	Подготовка и повышение квалификации специалистов по защите информации в соответствии с требованиями к направлению подготовки
Корпоративный уровень	Частная политика безопасности инфраструктуры контейнеризации, частные регламенты выявления, реагирования и ликвидации последствий инцидентов, порядок допуска рабочих нагрузок к развёртыванию [84–87]	Политики допуска рабочих нагрузок, механизм RBAC с минимально необходимыми полномочиями, сетевые политики, проверка подписи образов, шифрование секретов, непрерывный контроль конфигурации [31–35, 62–64]	Разграничение ответственности между подразделениями разработки и эксплуатации, включение показателей риска в критерии приёмки изменений
Личный уровень	Соблюдение разработчиком и администратором установленного порядка развёртывания рабочих нагрузок и обращения с конфиденциальными параметрами	Применение индивидуальных средств аутентификации при обращении к плоскости управления, неиспользование учётных записей с расширенными полномочиями в повседневной работе	Освоение практик безопасной разработки контейнерных приложений

Приведённая классификация обнаруживает, что основной объём мер, влияющих на меру риска рассматриваемого объекта, сосредоточен на корпоративном уровне, поскольку именно там принимаются решения о параметрах развёртывания рабочих нагрузок. Меры государственного и надгосударственного уровня задают обязательные требования и источники сведений об угрозах, но не определяют значений параметров конкретного кластера, а меры личного уровня влияют на вероятность ошибочного действия, не изменяя множества реализуемых сценариев компрометации. Из этого следует, что меры корпоративного уровня подлежат детализации до частных регламентов, что и выполняется далее.

2.2 Частные регламенты противодействия компрометации контейнерных приложений

Частные регламенты разрабатываются применительно к сценариям компрометации, отнесённым при построении риск-ландшафта к критическому и высокому уровням, и охватывают три этапа противодействия: выявление и регистрацию инцидента, реагирование на него и ликвидацию последствий. Разделение на указанные этапы соответствует порядку, установленному национальными стандартами управления компьютерными инцидентами [84–86] и руководством по обработке инцидентов информационной безопасности [87].

2.2.1 Частный регламент выявления и регистрации инцидентов

Выявление инцидента в инфраструктуре контейнеризации основывается на трёх группах источников событий: журнале обращений к серверу программных интерфейсов, событиях среды исполнения контейнеров и результатах непрерывного контроля конфигурации кластера. Каждому сценарию компрометации, выявленному при построении риск-ландшафта, ставится в соответствие перечень признаков, наблюдаемых при его реализации, и источник, в котором эти признаки регистрируются. Состав признаков приведён в таблице 11.

Таблица 11 – Признаки реализации сценариев компрометации и источники их регистрации

Сценарий	Наблюдаемый признак	Источник события	Действие по регистрации
С1, С4	Создание пода с признаком привилегированного режима либо с монтированием каталога узла	Журнал обращений к серверу программных интерфейсов, контроллер допуска	Регистрация инцидента категории «нарушение изоляции рабочей нагрузки», уведомление администратора безопасности
С1, С6	Обращение сервисного аккаунта прикладной нагрузки к объектам за пределами её пространства имён	Журнал обращений к серверу программных интерфейсов	Регистрация инцидента категории «превышение полномочий», фиксация учётной записи и времени
С2	Создание рабочей нагрузки от имени сервисного аккаунта прикладного приложения	Журнал обращений к серверу программных интерфейсов	Регистрация инцидента категории «несанкционированное развёртывание»
С3	Обращение процесса контейнера к сокету среды	События среды исполнения, средство	Регистрация инцидента категории «выход за

Сценарий	Наблюдаемый признак	Источник события	Действие по регистрации
	исполнения контейнеров	обнаружения аномального поведения [61]	границы контейнера»
С5	Запуск контейнера из образа, подпись которого не проверена либо не соответствует доверенной	Контроллер допуска, средство проверки подписи образов [64]	Блокирование развёртывания, регистрация инцидента категории «нарушение целостности образа»
С9	Потребление рабочей нагрузкой вычислительных ресурсов узла сверх установленного предела	Подсистема мониторинга ресурсов узла	Регистрация инцидента категории «нарушение доступности»
С10	Отключение либо изменение параметров журналирования, удаление записей журнала	Журнал обращений к серверу программных интерфейсов, подсистема мониторинга целостности	Регистрация инцидента категории «сокрытие следов», повышение приоритета расследования

Регистрации подлежит каждый выявленный признак независимо от того, привёл ли он к наступлению ущерба, поскольку накопленные записи образуют статистическую основу для последующего уточнения вероятностей переходов в графе достижимости. Срок хранения записей устанавливается не менее срока, необходимого для восстановления полной последовательности действий нарушителя, и определяется глубиной сценариев компрометации, выявленных при построении риск-ландшафта.

2.2.2 Частный регламент реагирования на инциденты

Реагирование на инцидент выполняется в порядке, определяемом уровнем меры риска сценария, признаки которого выявлены. Для сценариев критического уровня (С1–С3) устанавливается незамедлительное реагирование, для сценариев высокого уровня (С4–С6) – реагирование в течение установленного регламентом времени, для прочих – реагирование в плановом порядке. Последовательность действий при реагировании включает:

– изоляцию скомпрометированной рабочей нагрузки посредством применения сетевой политики, запрещающей её сетевое взаимодействие, с сохранением состояния контейнера для последующего исследования;

– отзыв маркера доступа сервисного аккаунта скомпрометированной рабочей нагрузки и всех производных от него полномочий;

– проверку целостности узла, на котором исполнялась рабочая нагрузка, и вывод узла из планирования при обнаружении признаков компрометации;

– проверку журнала обращений к серверу программных интерфейсов на предмет действий, выполненных от имени скомпрометированного сервисного аккаунта, и определение множества фактически достигнутых нарушителем активов;

– принудительную смену конфиденциальных параметров, доступных скомпрометированной рабочей нагрузке и смежным нагрузкам того же узла;

– приостановку развёртывания образов, полученных из реестра, в отношении которого имеются признаки подмены содержимого.

Существенным отличием реагирования в инфраструктуре контейнеризации от реагирования в традиционной информационной системе является возможность замещения скомпрометированной рабочей нагрузки её новым экземпляром, создаваемым из доверенного образа, без прерывания обслуживания. Данное обстоятельство позволяет выполнять изоляцию скомпрометированного экземпляра незамедлительно, не согласовывая её с требованиями непрерывности предоставления сервиса, что снижает величину наступающего ущерба.

2.2.3 Частный регламент ликвидации последствий инцидентов

Ликвидация последствий инцидента включает восстановление штатного состояния объекта защиты и устранение недостатков конфигурации, сделавших реализованный сценарий осуществимым. Перечень выполняемых действий:

– восстановление состава рабочих нагрузок из доверенных манифестов и образов с неизменяемыми идентификаторами содержимого;

– пересмотр привязок ролей механизма RBAC, предоставленных скомпрометированной рабочей нагрузке и нагрузкам того же пространства имён, с приведением полномочий к минимально необходимому объёму;

– приведение параметров изоляции рабочих нагрузок в соответствие с политикой допуска: отказ от привилегированного режима, монтирования каталогов узла и пространств имён узла;

– установление запрета на развёртывание образов, не прошедших проверку подписи, и ограничение перечня допустимых реестров образов;

– восстановление полноты журналирования обращений к серверу программных интерфейсов и установленной глубины хранения журналов;

– повторное построение риск-ландшафта кластера и сопоставление полученных значений меры риска со значениями, зафиксированными до наступления инцидента.

Завершающим действием регламента является внесение реализованного сценария и наблюдавшихся признаков в базу знаний, используемую при оценке риска, вследствие чего накопленные сведения об инцидентах уточняют вероятностные оценки, применяемые при последующих расчётах.

2.3 Оценка достигаемого снижения меры риска

Методические рекомендации требуют, чтобы предлагаемые меры оценивались по достигаемому результату, а не приводились в виде перечня [71]. Применительно к рассматриваемому объекту результатом применения меры является изменение меры риска сценария компрометации: мера воздействует либо на вероятность перехода в графе достижимости, устраняя недостаток конфигурации, делающий переход осуществимым, либо на величину ущерба, сокращая множество активов, достижимых по данному пути. Расчётные значения меры риска до и после применения мер корпоративного уровня приведены в таблице 12.

Таблица 12 – Оценка достигаемого снижения меры риска для сценариев компрометации

Сценарий	R до применения мер	Применяемая мера риск-регулирования	R после применения мер	Снижение, %
C1	0,72	Политика допуска, запрещающая привилегированный режим и монтирование каталогов узла; приведение привязок ролей к минимальному объёму	0,14	80
C2	0,63	Отключение автомонтирования маркера доступа для нагрузок, не обращающихся к плоскости управления; запрет прав на создание нагрузок	0,13	79
C3	0,54	Запрет монтирования сокета среды исполнения; принудительное разграничение доступа средствами модулей безопасности ядра	0,11	80

Сценарий	R до применения мер	Применяемая мера риск-регулирования	R после применения мер	Снижение, %
C4	0,45	Аутентификация обращений к агенту узла; ограничение перечня монтируемых каталогов	0,14	69
C5	0,38	Проверка подписи образа, перечень допустимых реестров, неизменяемые идентификаторы содержимого	0,08	79
C6	0,30	Пересмотр привязок ролей уровня кластера, разделение пространств имён	0,09	70
C7	0,24	Сетевые политики, запрет использования сетевого пространства имён узла	0,08	67
C8	0,18	Запрет исполнения процесса от имени суперпользователя и повышения привилегий	0,06	67
C9	0,12	Установление ограничений на потребление вычислительных ресурсов	0,04	67
C10	0,08	Восстановление полноты журналирования, вынесение журналов за пределы узла	0,03	63

Приведённые значения получены в предположении, что применение меры снижает вероятность соответствующего перехода до остаточного уровня, определяемого возможностью её обхода, и не изменяет величины ущерба, наступающего при успешной реализации сценария. Суммарная мера риска, вычисленная по множеству рассмотренных сценариев, снижается при этом более чем в четыре раза, причём наибольший вклад в снижение дают меры, устраняющие недостатки конфигурации рабочих нагрузок и сервисных аккаунтов, то есть меры, применяемые на этапе развёртывания, а не на этапе эксплуатации.

Существенно, что ни одна из перечисленных мер не устраняет риск полностью: остаточная мера риска сохраняется вследствие принципиальной осуществимости обхода отдельных ограничений и вследствие возможности появления новых рабочих нагрузок с отличными параметрами. Это подтверждает необходимость непрерывной переоценки риск-ландшафта, положенную в основу разрабатываемой интеллектуальной системы, и определяет критерий выбора мер: предпочтение отдаётся мере, дающей наибольшее снижение суммарной меры риска при сопоставимых затратах на её применение.

2.4 Выводы по второму разделу

Выполненная в настоящем разделе выработка мер риск-регулирования инфраструктуры контейнеризации позволила получить следующие результаты.

– сформирован комплекс мер риск-регулирования, классифицированных по масштабности (надгосударственные, государственные, корпоративные и личные) и по профильности (организационно-правовые, технические и прочие), и установлено, что основной объём мер, влияющих на меру риска рассматриваемого объекта, сосредоточен на корпоративном уровне;

– разработаны частные регламенты выявления и регистрации инцидентов, реагирования на них и ликвидации их последствий, привязанные к сценариям компрометации, отнесённым к критическому и высокому уровням риска, с указанием наблюдаемых признаков и источников их регистрации;

– выполнена оценка достигаемого снижения меры риска для каждого сценария компрометации, показавшая снижение суммарной меры риска более чем в четыре раза и наибольшую результативность мер, применяемых на этапе развёртывания рабочих нагрузок;

– установлено, что остаточная мера риска сохраняется при любом составе применённых мер, чем обосновывается требование непрерывной переоценки риск-ландшафта, предъявляемое к разрабатываемой интеллектуальной системе.

Полученные результаты завершают третий такт исследования и совместно с результатами первого раздела образуют законченное описание объекта защиты, индуцированных им рисков и мер их регулирования, достаточное для перехода к разработке методического, алгоритмического и программного обеспечения интеллектуальной системы в рамках выпускной квалификационной работы.

ЗАКЛЮЧЕНИЕ

В ходе научно-исследовательской работы выполнено исследование инфраструктуры контейнеризации Kubernetes как объекта защиты, проведена оценка индуцированных её компрометацией киберрисков и выработаны меры их регулирования, чем реализована предусмотренная методическими рекомендациями последовательность тактов «дерево угроз и индуцированных рисков – оценка рисков – меры риск-регулирования» [71].

Основные результаты работы состоят в следующем.

– построена модель инфраструктуры контейнеризации Kubernetes как объекта защиты, включающая четыре группы активов – плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов – и четыре границы доверия между ними; обосновано положение рабочей нагрузки в качестве начального, а не конечного звена цепочки компрометации;

– установлено соответствие между мерами защиты информации, предусмотренными нормативными документами, и параметрами конфигурации кластера, посредством которых эти меры реализуются, чем определено множество контролируемых параметров объекта защиты;

– предложена классификация недостатков конфигурации кластера по активам объекта защиты, объединяющая пять групп и обладающая свойством полноты относительно принятой модели;

– установлена неприменимость международных реестров уязвимостей CVE и NVD, банка данных угроз безопасности информации ФСТЭК России и калькуляторов критичности CVSS и EPSS к недостаткам конфигурации кластера вследствие несовпадения областей определения, и обоснован состав источников, пригодных для формирования множества недостатков и техник их эксплуатации;

– выполнен сравнительный анализ средств анализа защищённости контейнерных сред, показавший, что все рассмотренные средства дают дискретную оценку соответствия профилю безопасности, оценивают объекты кластера

изолированно и не предусматривают переоценки состояния при изменении конфигурации;

– построено дерево угроз и индуцированных ими рисков инфраструктуры контейнеризации, содержащее четыре угрозы и двенадцать индуцированных рисков, системообразующим событием которого является компрометация контейнерного приложения;

– построен риск-ландшафт объекта защиты: сформирован граф достижимости активов кластера, выделены десять типовых сценариев компрометации и для каждого вычислена мера риска как произведение вероятности наступления ущерба на его величину;

– выявлены пять противоречий, поставлены пять задач исследования и сформулированы пять выносимых на защиту результатов, чем обеспечена согласованность целеполагания; сформированы восемь требований к разрабатываемому методическому, алгоритмическому и программному обеспечению;

– сформирован комплекс мер риск-регулирования, классифицированных по масштабности и профильности, разработаны частные регламенты выявления, реагирования и ликвидации последствий инцидентов и выполнена оценка достигаемого снижения меры риска.

Полученные результаты образуют законченное описание объекта защиты и индуцированных им рисков и составляют содержание первого раздела выпускной квалификационной работы по теме «Разработка интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes в условиях компрометации контейнерных приложений». Разработанные частные регламенты и комплекс мер риск-регулирования составляют основу заключительного раздела указанной работы.

Направлением дальнейшего исследования является разработка базы знаний соответствий недостатков конфигурации и эксплуатирующих их техник, методики количественной оценки меры риска компрометации контейнерного приложения и программного обеспечения интеллектуальной системы, выполняющей

классификацию рабочих нагрузок по уровню риска и пересчёт риск-ландшафта при изменении конфигурации кластера.

СПИСОК ЛИТЕРАТУРЫ

1. Доктрина информационной безопасности Российской Федерации: утверждена Указом Президента Российской Федерации от 5 декабря 2016 г. № 646. – Электрон. дан. – Режим доступа: http://publication.pravo.gov.ru/Document/View/0001201612060002. – Текст: электронный.

2. Об информации, информационных технологиях и о защите информации: Федеральный закон от 27 июля 2006 г. № 149-ФЗ. – Электрон. дан. – Режим доступа: http://www.consultant.ru/document/cons_doc_LAW_61798/. – Текст: электронный.

3. О персональных данных: Федеральный закон от 27 июля 2006 г. № 152-ФЗ. – Электрон. дан. – Режим доступа: http://www.consultant.ru/document/cons_doc_LAW_61801/. – Текст: электронный.

4. Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах: приказ ФСТЭК России от 11 февраля 2013 г. № 17. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-11-fevralya-2013-g-n-17. – Текст: электронный.

5. Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных: приказ ФСТЭК России от 18 февраля 2013 г. № 21. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-18-fevralya-2013-g-n-21. – Текст: электронный.

6. Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации: приказ ФСТЭК России от 25 декабря 2017 г. № 239. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-25-dekabrya-2017-g-n-239. – Текст: электронный.

7. Методика оценки угроз безопасности информации: методический документ ФСТЭК России, утверждён 5 февраля 2021 г. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/spetsialnye-normativnye-dokumenty/metodicheskij-dokument-ot-5-fevralya-2021-g. – Текст: электронный.

8. ГОСТ Р 50922-2006. Защита информации. Основные термины и определения. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200058320. – Текст: электронный.

9. ГОСТ Р 56545-2015. Защита информации. Уязвимости информационных систем. Правила описания уязвимостей. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

10. ГОСТ Р 56546-2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

11. ГОСТ Р 56938-2016. Защита информации. Защита информации при использовании технологий виртуализации. Общие положения. – Москва: Стандартинформ, 2016. – Текст: непосредственный.

12. ГОСТ Р 59547-2021. Защита информации. Мониторинг информационной безопасности. Общие положения. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200180385. – Текст: электронный.

13. ГОСТ Р ИСО/МЭК 27001-2021. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200181890. – Текст: электронный.

14. ГОСТ Р ИСО/МЭК 27005-2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – Москва: Стандартинформ, 2011. – Текст: непосредственный.

15. ГОСТ Р ИСО 31000-2019. Менеджмент риска. Принципы и руководство. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

16. ГОСТ Р 58771-2019. Менеджмент риска. Технологии оценки риска. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

17. ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection – Information security controls. – Электрон. дан. – Режим доступа: https://www.iso.org/standard/75652.html. – Текст: электронный.

18. ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection – Guidance on managing information security risks. – Электрон. дан. – Режим доступа: https://www.iso.org/standard/80585.html. – Текст: электронный.

19. NIST Special Publication 800-190. Application Container Security Guide. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-190/final. – Текст: электронный.

20. NIST Special Publication 800-204. Security Strategies for Microservices-based Application Systems. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-204/final. – Текст: электронный.

21. NIST Special Publication 800-204A. Building Secure Microservices-based Applications Using Service-Mesh Architecture. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-204a/final. – Текст: электронный.

22. NIST Special Publication 800-207. Zero Trust Architecture. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-207/final. – Текст: электронный.

23. NIST Special Publication 800-30 Revision 1. Guide for Conducting Risk Assessments. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final. – Текст: электронный.

24. NIST Special Publication 800-39. Managing Information Security Risk: Organization, Mission, and Information System View. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-39/final. – Текст: электронный.

25. CIS Kubernetes Benchmark: набор проверок конфигурации кластера центра интернет-безопасности. – Электрон. дан. – Режим доступа: https://www.cisecurity.org/benchmark/kubernetes. – Текст: электронный.

26. CIS Docker Benchmark: набор проверок конфигурации среды исполнения контейнеров. – Электрон. дан. – Режим доступа: https://www.cisecurity.org/benchmark/docker. – Текст: электронный.

27. Kubernetes Hardening Guide: руководство Агентства национальной безопасности и Агентства по кибербезопасности и защите инфраструктуры США. – Электрон. дан. – Режим доступа: https://www.cisa.gov/resources-tools/resources/kubernetes-hardening-guide. – Текст: электронный.

28. OWASP Kubernetes Top Ten: перечень наиболее значимых рисков безопасности инфраструктуры Kubernetes. – Электрон. дан. – Режим доступа: https://owasp.org/www-project-kubernetes-top-ten/. – Текст: электронный.

29. Cloud Native Security Whitepaper: документ рабочей группы по безопасности фонда Cloud Native Computing Foundation. – Электрон. дан. – Режим доступа: https://www.cncf.io/reports/. – Текст: электронный.

30. Kubernetes Documentation: официальная документация системы оркестрации контейнерных приложений. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/. – Текст: электронный.

31. Pod Security Standards: стандарты безопасности рабочих нагрузок Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/concepts/security/pod-security-standards/. – Текст: электронный.

32. Using RBAC Authorization: механизм управления доступом на основе ролей в Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/reference/access-authn-authz/rbac/. – Текст: электронный.

33. Kubernetes Security Checklist: перечень контролируемых параметров безопасности кластера. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/concepts/security/security-checklist/. – Текст: электронный.

34. Secrets: механизм хранения конфиденциальных параметров в Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/concepts/configuration/secret/. – Текст: электронный.

35. Admission Controllers Reference: контроллеры допуска рабочих нагрузок в Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/reference/access-authn-authz/admission-controllers/. – Текст: электронный.

36. etcd: распределённое хранилище состояния кластера. – Электрон. дан. – Режим доступа: https://etcd.io/docs/. – Текст: электронный.

37. containerd: среда исполнения контейнеров. – Электрон. дан. – Режим доступа: https://containerd.io/docs/. – Текст: электронный.

38. Банк данных угроз безопасности информации ФСТЭК России. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

39. Common Vulnerabilities and Exposures (CVE). – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

40. National Vulnerability Database (NVD). – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

41. Common Weakness Enumeration (CWE). – Электрон. дан. – Режим доступа: https://cwe.mitre.org/. – Текст: электронный.

42. Common Attack Pattern Enumeration and Classification (CAPEC). – Электрон. дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

43. MITRE ATT&CK Enterprise Matrix. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

44. MITRE ATT&CK Containers Matrix. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/containers/. – Текст: электронный.

45. MITRE ATT&CK. Deploy Container, T1610. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1610/. – Текст: электронный.

46. MITRE ATT&CK. Escape to Host, T1611. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1611/. – Текст: электронный.

47. MITRE ATT&CK. Container Administration Command, T1609. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1609/. – Текст: электронный.

48. MITRE ATT&CK. Container and Resource Discovery, T1613. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1613/. – Текст: электронный.

49. MITRE ATT&CK. Unsecured Credentials: Container API, T1552.007. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1552/007/. – Текст: электронный.

50. MITRE ATT&CK. Implant Internal Image, T1525. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1525/. – Текст: электронный.

51. MITRE ATT&CK. Build Image on Host, T1612. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1612/. – Текст: электронный.

52. MITRE ATT&CK. Resource Hijacking, T1496. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1496/. – Текст: электронный.

53. MITRE ATT&CK. Valid Accounts, T1078. – Электрон. дан. – Режим доступа: https://attack.mitre.org/techniques/T1078/. – Текст: электронный.

54. Common Vulnerability Scoring System v3.1: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/specification-document. – Текст: электронный.

55. Common Vulnerability Scoring System v4.0: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/specification-document. – Текст: электронный.

56. Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss/. – Текст: электронный.

57. OWASP Risk Rating Methodology. – Электрон. дан. – Режим доступа: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology. – Текст: электронный.

58. kube-bench: средство проверки конфигурации кластера на соответствие CIS Kubernetes Benchmark. – Электрон. дан. – Режим доступа: https://github.com/aquasecurity/kube-bench. – Текст: электронный.

59. Kubescape: средство анализа защищённости кластера Kubernetes. – Электрон. дан. – Режим доступа: https://github.com/kubescape/kubescape. – Текст: электронный.

60. Trivy: средство выявления уязвимостей образов контейнеров и ошибок конфигурации. – Электрон. дан. – Режим доступа: https://github.com/aquasecurity/trivy. – Текст: электронный.

61. Falco: средство обнаружения аномального поведения среды исполнения контейнеров. – Электрон. дан. – Режим доступа: https://falco.org/docs/. – Текст: электронный.

62. Open Policy Agent Gatekeeper: средство контроля политик допуска рабочих нагрузок. – Электрон. дан. – Режим доступа: https://open-policy-agent.github.io/gatekeeper/. – Текст: электронный.

63. Kyverno: средство управления политиками безопасности Kubernetes. – Электрон. дан. – Режим доступа: https://kyverno.io/docs/. – Текст: электронный.

64. Sigstore: инфраструктура подписи и проверки происхождения образов контейнеров. – Электрон. дан. – Режим доступа: https://www.sigstore.dev/. – Текст: электронный.

65. State of Kubernetes Security Report: ежегодный аналитический отчёт компании Red Hat. – Электрон. дан. – Режим доступа: https://www.redhat.com/en/resources/state-kubernetes-security-report. – Текст: электронный.

66. Cloud-Native Security and Usage Report: ежегодный аналитический отчёт компании Sysdig. – Электрон. дан. – Режим доступа: https://sysdig.com/. – Текст: электронный.

67. CNCF Annual Survey: ежегодное исследование фонда Cloud Native Computing Foundation. – Электрон. дан. – Режим доступа: https://www.cncf.io/reports/. – Текст: электронный.

68. Verizon Data Breach Investigations Report. – Электрон. дан. – Режим доступа: https://www.verizon.com/business/resources/reports/dbir/. – Текст: электронный.

69. Утечки данных в России и мире: аналитический отчёт экспертно-аналитического центра InfoWatch. – Электрон. дан. – Режим доступа: https://www.infowatch.ru/analytics. – Текст: электронный.

70. Актуальные киберугрозы: аналитические отчёты компании Positive Technologies. – Электрон. дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/. – Текст: электронный.

71. Остапенко А.Г. Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности / А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.А. Остапенко, А.В. Заряев, Т.Ю. Мирошниченко, П.Д. Федоров // Информация и безопасность. 2020. Т. 23. Вып. 4. С. 551-560. – Текст: непосредственный.

72. Организационно-правовая защита сетей / Г.А. Остапенко и др.; под ред. академика РАН Д.А. Новикова. Сер. Теория сетевых войн. Вып. 8. – Москва: Горячая линия – Телеком, 2023. – 228 с. – Текст: непосредственный.

73. Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 203-210. – Текст: непосредственный.

74. Пекло А.Ю. Атаки типа «сетевая разведка»: риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 4. С. 597-602. – Текст: непосредственный.

75. Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 159-178. – Текст: непосредственный.

76. Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420. – Текст: непосредственный.

77. Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и др.] //

Информация и безопасность. 2024. Т. 27. Вып. 2. С. 231-238. – Текст: непосредственный.

78. Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484. – Текст: непосредственный.

79. Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. Т. 26. Вып. 3. С. 447-454. – Текст: непосредственный.

80. Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400. – Текст: непосредственный.

81. Caralli R.A. Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process / R.A. Caralli, J.F. Stevens, L.R. Young, W.R. Wilson. Technical Report CMU/SEI-2007-TR-012. – Pittsburgh: Software Engineering Institute, Carnegie Mellon University, 2007. – Текст: непосредственный.

82. Freund J. Measuring and Managing Information Risk: A FAIR Approach / J. Freund, J. Jones. – Waltham: Butterworth-Heinemann, 2015. – Текст: непосредственный.

83. Risk Analysis (O-RA), Version 2.0: стандарт консорциума The Open Group. – Электрон. дан. – Режим доступа: https://www.opengroup.org/. – Текст: электронный.

84. ГОСТ Р 59709-2022. Защита информации. Управление компьютерными инцидентами. Термины и определения. – Москва: Российский институт стандартизации, 2022. – Текст: непосредственный.

85. ГОСТ Р 59710-2022. Защита информации. Управление компьютерными инцидентами. Общие положения. – Москва: Российский институт стандартизации, 2022. – Текст: непосредственный.

86. ГОСТ Р 59712-2022. Защита информации. Управление компьютерными инцидентами. Руководство по реагированию на компьютерные инциденты. – Москва: Российский институт стандартизации, 2022. – Текст: непосредственный.

87. NIST Special Publication 800-61 Revision 2. Computer Security Incident Handling Guide. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final. – Текст: электронный.

88. NIST Special Publication 800-53 Revision 5. Security and Privacy Controls for Information Systems and Organizations. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final. – Текст: электронный.

89. NIST Special Publication 800-137. Information Security Continuous Monitoring for Federal Information Systems and Organizations. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-137/final. – Текст: электронный.

90. MITRE D3FEND: база знаний мер противодействия техникам нарушителя. – Электрон. дан. – Режим доступа: https://d3fend.mitre.org/. – Текст: электронный.

91. CIS Critical Security Controls Version 8: перечень критических мер обеспечения безопасности центра интернет-безопасности. – Электрон. дан. – Режим доступа: https://www.cisecurity.org/controls/v8. – Текст: электронный.

92. Kubernetes Threat Model: модель угроз системы оркестрации контейнерных приложений, подготовленная рабочей группой по безопасности фонда Cloud Native Computing Foundation. – Электрон. дан. – Режим доступа: https://github.com/kubernetes/sig-security. – Текст: электронный.

93. Sultan S. Container Security: Issues, Challenges, and the Road Ahead / S. Sultan, I. Ahmad, T. Dimitriou // IEEE Access. – 2019. – Vol. 7. – P. 52976–52996. – Текст: непосредственный.

94. Shamim M. S. I. XI Commandments of Kubernetes Security: A Systematization of Knowledge Related to Kubernetes Security Practices / M. S. I. Shamim, F. A. Bhuiyan,

A. Rahman // Proceedings of the IEEE Secure Development Conference (SecDev). – 2020. – P. 58–64. – Текст: непосредственный.

95. Bose D. B. «Under-reported» Security Defects in Kubernetes Manifests / D. B. Bose, A. Rahman, S. I. Shamim // Proceedings of the IEEE/ACM 2nd International Workshop on Engineering and Cybersecurity of Critical Systems (EnCyCriS). – 2021. – P. 9–12. – Текст: непосредственный.

96. Rahman A. Security Misconfigurations in Open Source Kubernetes Manifests: An Empirical Study / A. Rahman, S. I. Shamim, D. B. Bose, R. Pandita // ACM Transactions on Software Engineering and Methodology. – 2023. – Vol. 32, № 4. – P. 1–36. – Текст: непосредственный.

97. Budigiri G. Network Policies in Kubernetes: Performance Evaluation and Security Analysis / G. Budigiri, C. Baumann, J. T. Mühlberg, E. Truong, W. Joosen // Proceedings of the Joint European Conference on Networks and Communications & 6G Summit (EuCNC). – 2021. – P. 407–412. – Текст: непосредственный.

98. Minna F. SoK: Run-time security for cloud microservices / F. Minna, F. Massacci // Computers & Security. – 2025. – Vol. 148. – P. 104–120. – Текст: непосредственный.

99. Язов Ю. К. Организация защиты информации в информационных системах от несанкционированного доступа / Ю. К. Язов, С. В. Соловьёв. – Воронеж: Кварта, 2018. – 588 с. – Текст: непосредственный.

100. Калашников А. О. Модели и методы организационного управления информационными рисками корпораций / А. О. Калашников. – Москва: Эгвес, 2011. – 312 с. – Текст: непосредственный.

ПРИЛОЖЕНИЕ А

Фрагмент базы знаний соответствий «недостаток конфигурации кластера – эксплуатирующая техника – наступающий ущерб»

Таблица А.1 – Фрагмент базы знаний соответствий недостатков конфигурации кластера и техник их эксплуатации

№	Группа актива	Недостаток конфигурации	Проверяемый параметр	Техника	Наступающий ущерб
1	Рабочие нагрузки	Запуск пода в привилегированном режиме	securityContext.privileged = true	T1611	Получение прав суперпользователя на узле
2	Рабочие нагрузки	Монтирование каталога узла в файловую систему контейнера	volumes.hostPath	T1611	Доступ к файловой системе и конфигурации узла
3	Рабочие нагрузки	Использование сетевого пространства имён узла	spec.hostNetwork = true	T1613	Доступ к сетевому окружению узла и обход сетевых политик
4	Рабочие нагрузки	Использование пространства имён процессов узла	spec.hostPID = true	T1057	Наблюдение процессов узла и извлечение их параметров
5	Рабочие нагрузки	Исполнение процесса контейнера от имени суперпользователя	securityContext.runAsNonRoot не задан	T1611	Расширение возможностей нарушителя в контейнере
6	Рабочие нагрузки	Отсутствие запрета повышения привилегий	allowPrivilegeEscalation = true	T1611	Повышение привилегий внутри контейнера
7	Рабочие нагрузки	Доступная на запись корневая файловая система	readOnlyRootFilesystem = false	T1610	Размещение постороннего исполняемого кода
8	Рабочие нагрузки	Отсутствие ограничений на потребление ресурсов	resources.limits не задан	T1496	Исчерпание вычислительных ресурсов узла
9	Сервисные аккаунты	Автоматическое монтирование маркера доступа	automountServiceAccountToken = true	T1552.007	Обращение к плоскости управления от имени нагрузки
10	Сервисные аккаунты	Привязка роли уровня кластера к прикладной нагрузке	ClusterRoleBinding на cluster-admin	T1078	Полное управление кластером
11	Сервисные аккаунты	Права на чтение конфиденциальных параметров	rules: secrets/get, list	T1552	Раскрытие секретов пространства имён
12	Сервисные аккаунты	Права на создание рабочих нагрузок	rules: pods/create	T1610	Развёртывание посторонней нагрузки на любом узле
13	Плоскость управления	Допуск анонимных обращений к серверу программных	--anonymous-auth = true	T1613	Получение сведений о составе кластера без аутентификации

№	Группа актива	Недостаток конфигурации	Проверяемый параметр	Техника	Наступающий ущерб
		интерфейсов			
14	Плоскость управления	Неполнота журналирования обращений	--audit-policy-file не задан	T1070	Невозможность установления обстоятельств инцидента
15	Плоскость управления	Отсутствие шифрования конфиденциальных параметров при хранении	--encryption-provider-config не задан	T1552	Раскрытие секретов при доступе к хранилищу etcd
16	Плоскость управления	Доступность хранилища etcd без взаимной аутентификации	--client-cert-auth = false	T1552	Получение полного состояния кластера
17	Плоскость управления	Отсутствие политик допуска рабочих нагрузок	Pod Security Admission не применяется	T1610	Развёртывание нагрузки с ослабленной изоляцией
18	Вычислительные узлы	Доступность сокета среды исполнения из рабочей нагрузки	монтирование /var/run/docker.sock	T1609	Управление всеми контейнерами узла
19	Вычислительные узлы	Допуск неаутентифицированных обращений к агенту узла	--anonymous-auth = true у kubelet	T1609	Исполнение команд в контейнерах узла
20	Вычислительные узлы	Отсутствие принудительного разграничения доступа средствами ядра	SELinux/AppArmor отключены	T1611	Отсутствие ограничений при выходе за границы контейнера
21	Вычислительные узлы	Отсутствие ограничений на перечень системных вызовов	seccompProfile не задан	T1611	Расширение поверхности воздействия на ядро узла
22	Реестр образов	Получение образов из произвольных внешних реестров	перечень допустимых реестров не задан	T1525	Исполнение постороннего кода
23	Реестр образов	Отсутствие проверки подписи образа	проверка подписи не выполняется	T1525	Развёртывание подменённого образа
24	Реестр образов	Использование изменяемых тегов образов	image: name:latest	T1525	Подмена содержимого образа без изменения манифеста
25	Реестр образов	Отсутствие контроля состава образа	перечень компонентов образа не формируется	T1612	Невозможность установления состава исполняемого кода

ПРИЛОЖЕНИЕ Б

Матрица целеполагания исследования

Таблица Б.1 – Матрица целеполагания исследования

№	Противоречия между	Задачи исследования	Результаты исследования	Новизна результатов	Практическая ценность результатов	Теоретическая ценность результатов
1	объективной необходимостью рассматривать кластер как связную систему активов с различными границами доверия — плоскостью управления, узлами, рабочими нагрузками и реестром образов — и сложившейся практикой оценки защищённости контейнерных сред по отдельным образам и их уязвимостям, при которой компрометация контейнерного приложения считается конечным событием, а не начальным звеном цепочки	декомпозиция инфраструктуры контейнеризации на активы и границы доверия и построение на её основе дерева угроз и индуцированных ими рисков, наступающих при компрометации контейнерных приложений	модель объекта защиты в виде декомпозиции кластера на активы и границы доверия и построенное на ней дерево угроз и индуцированных рисков	впервые дерево угроз построено для кластера как связной системы, в которой компрометация контейнерного приложения выступает начальным, а не конечным событием, что позволяет включить в рассмотрение переходы между границами доверия	применение модели позволяет специалисту очертить границы объекта защиты и получить перечень контролируемых узлов кластера при проектировании защиты контейнерной платформы	полученная декомпозиция может быть распространена на иные платформы оркестрации — OpenShift, Nomad — и служит основой для анализа защищённости сервисных сеток
2	потребностью в едином описании недостатков конфигурации кластера — привилегированных подов, монтирования узловых каталогов, избыточных привязок RBAC, неограниченного доступа к API-серверу — и ориентированностью баз данных уязвимостей — CVE, NVD, банка данных	формирование базы знаний соответствий недостатков конфигурации кластера и эксплуатирующих их техник на основе CIS Kubernetes Benchmark, NIST SP 800-190 и матрицы MITRE ATT&CK for Containers с привязкой каждой пары к наступающему ущербу	база знаний троек «недостаток конфигурации кластера — эксплуатирующая техника — наступающий ущерб», покрывающая все выделенные активы объекта защиты	впервые недостатки конфигурации Kubernetes, не обладающие идентификаторами уязвимостей, поставлены в однозначное соответствие техникам их эксплуатации и представлены в форме, пригодной для машинной обработки	применение базы позволяет получить готовый перечень проверяемых параметров кластера с указанием техники эксплуатации и ожидаемого ущерба без обращения к разрозненным источникам	полученное соответствие может быть расширено на шаблоны инфраструктуры как кода и политики допуска рабочих нагрузок, а также использовано для корреляционного анализа накопленных данных

№	Противоречия между	Задачи исследования	Результаты исследования	Новизна результатов	Практическая ценность результатов	Теоретическая ценность результатов
	угроз ФСТЭК России — на дефекты программного кода, вследствие чего перечисленные недостатки не получают идентификатора и выпадают из риск-анализа					
3	необходимостью количественного выражения критичности недостатков конфигурации кластера и инструментальной базой оценки критичности, представленной метриками CVSS версий 3.1 и 4.0 и прогнозной оценкой эксплуатации EPSS, которые построены для уязвимостей с присвоенным идентификатором и накопленной статистикой эксплуатации, отсутствующей у конфигурационных недостатков	разработка методики количественной оценки вероятности успешной компрометации контейнерного приложения и наступающего ущерба на основе адаптации базовых, контекстных и средовых метрик CVSS 4.0 к контексту кластера	методика и реализующий её алгоритм расчёта меры риска компрометации контейнерного приложения, определяемой как произведение вероятности наступления ущерба на его величину	впервые количественная оценка критичности получена для недостатков без идентификатора уязвимости за счёт переноса метрик на контекст кластера: уровень привилегий пода, пересекаемую границу доверия и доступность плоскости управления	применение методики позволяет оперативно вычислять параметры риска компрометации отдельной рабочей нагрузки и ранжировать нагрузки кластера по критичности	полученный подход может быть распространён на иные классы объектов защиты, не обладающих идентификаторами уязвимостей
4	необходимостью учёта сочетаемости недостатков, образующих цепочки «выход за границы контейнера — компрометация узла — доступ к плоскости управления», и пообъектным характером проверок средств анализа защищённости Kubescape, kube-bench, Trivy и Falco, оценивающих каждый	формирование типовых сценариев компрометации кластера в виде путей достижимости активов, размеченных техниками MITRE ATT&CK for Containers, с расчётом риска успешности каждого сценария и построением риск-ландшафта	множество сценариев компрометации, представленных путями в графе достижимости, и риск-ландшафт кластера, построенный по осям «актив кластера», «техника эксплуатации» и «мера риска»	впервые риск кластера определяется не суммой независимых несоответствий профилю, а достижимостью целевых активов по графу сценариев, что учитывает взаимное усиление недостатков конфигурации	применение риск-ландшафта позволяет выявить сочетания недостатков с наибольшей мерой риска и сосредоточить защитные ресурсы на сценариях, ведущих к плоскости управления	полученный граф достижимости может быть сужен до актуального множества сценариев либо расширен на мультикластерные и гибридные среды

№	Противоречия между	Задачи исследования	Результаты исследования	Новизна результатов	Практическая ценность результатов	Теоретическая ценность результатов
	объект кластера изолированно					
5	потребностью в удержании оценки риска в актуальном состоянии при непрерывном изменении состава рабочих нагрузок, версий образов и политик доступа и статичностью действующих методик, предполагающих разовое обследование кластера по фиксированному профилю соответствия	создание интеллектуальной системы оценки и регулирования киберрисков кластера, выполняющей классификацию рабочих нагрузок по уровню риска средствами машинного обучения и пересчёт риск-ландшафта при смене снимка конфигурации, и формирование комплекса мер регулирования, классифицированных по масштабности и профильности	программное обеспечение интеллектуальной системы с моделью классификации рабочих нагрузок по уровню риска, обученной на размеченном множестве манифестов, и комплекс мер регулирования риск-ландшафта кластера с оценкой достигаемого снижения меры риска	впервые уровень риска рабочей нагрузки определяется обученной моделью по совокупности параметров её манифеста, а меры регулирования оцениваются величиной снижения меры риска, а не фактом соответствия профилю безопасности	применение системы снимает необходимость ручного аудита при каждом изменении кластера и даёт обоснование выбора мер защиты по критерию достигаемого снижения риска	полученное обеспечение может быть распространено на оптимизацию риск-ландшафта контейнерных сред различного назначения